РОССИЙСКИЙ УНИВЕРСИТЕТ ДРУЖБЫ НАРОДОВ

Факультет физико-математических и естественных наук

Кафедра прикладной информатики и теории вероятностей

ОТЧЕТ

ПО ЛАБОРАТОРНОЙ РАБОТЕ № 5

Защита целевых систем ЦОД

Киберучения в формате Blue Team

Выполнили

Рогозин Игорь

Гусейнов Тагир

Райко Матвей

Группа НБИбд-01-23

Дата выполнения

28 октября 2026 года

Москва

2026

Содержание

1 Введение 3–3
1.1 Цель работы 3–3
1.2 Задачи 3–3
2 Сценарий и используемый стенд 3–4
2.1 Ресурсы 4–4
2.2 Модель угроз 4–4
3 Краткие теоретические сведения 5–5
3.1 Уязвимость плагина WordPress 5–5
3.2 Zerologon 5–5
3.3 Панель управления Exchange 5–5
4 Обнаружение и восстановление последовательности атаки 6–14
4.1 События на WordPress 6–8
4.2 События на контроллере домена 9–11
4.3 События на Exchange 11–13
4.4 Хронология 14–14
5 Расследование и восстановление WordPress 15–21
5.1 Веб-корень и время 15–16
5.2 Подменённое изображение 16–16
5.3 Вредоносные плагины 17–18
5.4 PHP-файлы в uploads 18–20
5.5 Отключение плагина и проверка сайта 20–21
6 Расследование на контроллере домена 22–25
6.1 Поиск бэкдора 22–23
6.2 Удаление закрепления 23–24
6.3 Защита Netlogon 24–25
6.4 Учётные записи и восстановление пароля 25–25
7 Расследование на сервере Exchange 26–30
7.1 Веб-шелл 26–27
7.2 Учётные записи и службы 27–29
7.3 Ограничение доступа к ECP 29–30
8 Инциденты и измерение результатов 31–33
8.1 Карточки инцидентов 31–32
8.2 Результаты локальных проверок 32–33
8.3 Оставшиеся меры 33–33
9 Заключение 34–34

1 Введение

Лабораторная работа посвящена реагированию на атаку на инфраструктуру центра обработки данных. В учебной среде Ampire исследованы корпоративный сайт WordPress, контроллер домена Active Directory и почтовый сервер Microsoft Exchange. Работа выполнена в формате Blue Team: после завершения атаки требовалось восстановить её последовательность, обнаружить закрепление, устранить доступные причины компрометации и восстановить изменённые ресурсы.

Основу расследования составили события ViPNet IDS NS, сведения о процессах и файлах целевых систем, параметры служб и результаты контрольных команд. Сетевые сигнатуры сопоставлялись с артефактами на узлах: отдельно оценивались факт обнаружения подозрительного трафика, наличие вредоносного файла и результат его удаления.

1.1 Цель работы

Цель работы — освоить расследование многоэтапного вторжения в инфраструктуру ЦОД и провести восстановительные мероприятия на трёх затронутых системах. Ожидаемый практический результат — восстановленный сайт, удалённые обнаруженные средства закрепления и проверенные ограничения доступа к уязвимым компонентам.

1.2 Задачи

Необходимо изучить легенду тренировки и состав стенда, определить источники событий и согласовать их время. По данным IDS требуется выделить эпизоды атаки на WordPress, Active Directory и Exchange, определить адреса участников и сопоставить сетевые события с результатами обследования узлов.

На WordPress требуется найти причину изменения сайта, восстановить изображение, проверить плагины и каталог загрузок, вывести обнаруженные вредоносные файлы из веб-корня. На контроллере домена необходимо проверить процессы, автозапуск и параметры Netlogon, удалить установленный бэкдор и оценить результат восстановления машинного пароля. На Exchange необходимо проверить веб-каталоги, удалить найденный веб-шелл, проверить связь с доменом и ограничить доступ к ECP.

Завершающие задачи — оформить карточки инцидентов, сопоставить локальные проверки со статусами Ampire и определить действия, которые остаются необходимыми для полного завершения восстановления.

2 Сценарий и используемый стенд

Работа выполнена 28 октября 2026 года в тренировке № 1092 «ЛР5 [НБИ-01-23 Alpha] v0», сценарий № 92 «Защита целевых систем ЦОД». По легенде внешний нарушитель заинтересован в нарушении работы компании: атакует публичный сайт, продвигается во внутреннюю сеть и получает доступ к инфраструктурным сервисам. К началу реагирования атака уже завершилась; расследование проводилось по оставленным событиям и артефактам.

2.1 Ресурсы

Основные адреса стенда перечислены ниже (таблица 1). Разделение внешнего сегмента, сети веб-сервера и внутренней сети позволяет оценить направление продвижения нарушителя.

Таблица 1 — Основные ресурсы учебного стенда

Ресурс	Адрес	Роль в работе
Внешний узел Kali	195.239.174.11	Источник внешних подключений и адрес в обнаруженном бэкдоре
WordPress	10.10.1.22	Веб-сервер web-portal-3; внешний адрес 195.239.174.87
Active Directory	10.10.2.10	Контроллер AD домена AMPIRE, лес ampire.corp
Microsoft Exchange	10.10.2.11	Почтовый сервер MAIL и веб-компоненты OWA/ECP
ViPNet IDS NS	10.10.2.21	Основной источник сетевых событий расследования
Security Onion	10.10.1.25	Дополнительный ресурс мониторинга стенда
Рабочая станция	10.10.4.12	Проведение административных проверок
Маршрутизаторы	10.10.1.253; 10.10.2.254	Связь веб-сегмента и внутренней сети
Пограничный шлюз	10.10.1.254; 195.239.174.1	Граница внешнего подключения

WordPress работал на Ubuntu 18.04.5 LTS с Apache; версия CMS — 5.8.2. Веб-корень сайта определён как `/var/www/html/wordpress`. Для Windows-систем использовались административные средства PowerShell, реестр, IIS Manager и оснастка управления пользователями домена. Основные выводы по сетевой активности получены из ViPNet IDS NS; отдельное исследование событий Security Onion в представленных материалах не зафиксировано.

2.2 Модель угроз

Публичный сайт образует начальную точку воздействия, а его доступ во внутренний сегмент создаёт возможность дальнейшего продвижения. В событиях атаки на Netlogon источником выступал уже адрес WordPress, а на Exchange наблюдались обращения к внешнему узлу и загрузка исполняемого содержимого. Эта последовательность согласуется с переходом от компрометации веб-сервера к атаке на доменную и почтовую инфраструктуру.

Наблюдаемые последствия охватывают изменение содержимого сайта, размещение исполняемых файлов в веб-каталогах, запуск Python-бэкдора на контроллере домена и установку веб-шелла на Exchange. Проверка каждого последствия выполнялась отдельно: устранение одного файла не означает автоматического восстановления доверия ко всей системе.

3 Краткие теоретические сведения

3.1 Уязвимость плагина WordPress

В параметрах сценария WordPress связан с Essential Addons и CVE-2023-32243. Эта уязвимость относится к повышению привилегий через несанкционированный сброс пароля. Получение административного доступа к CMS создаёт условия для изменения сайта и установки дополнительного кода. В исследованной системе обнаружен компонент версии 5.7.1, выведенный из каталога плагинов при восстановлении.

Сетевое событие загрузки ELF и наличие PHP-бэкдоров подтверждают отдельные проявления компрометации. Однако они не содержат полного запроса, которым первоначально использовалась уязвимость плагина. Поэтому начальный способ получения доступа определяется по данным сценария, а последующие действия — по фактически найденным артефактам.

3.2 Zerologon

Zerologon, CVE-2020-1472, затрагивает протокол Netlogon и позволяет нарушить проверку подлинности защищённого канала. Для расследования характерна последовательность вызовов NetrServerReqChallenge, NetrServerAuthenticate3 и NetrServerPasswordSet2. На данном стенде IDS зарегистрировала все три фазы со стороны веб-сервера в направлении контроллера домена.

Параметр `FullSecureChannelProtection` относится к принудительному применению защиты Netlogon. Его значение необходимо оценивать совместно с установленными обновлениями Windows: наличие единицы в реестре само по себе не подтверждает установку исправления. Порядок развёртывания обновлений и включения защиты описан в документации Microsoft по CVE-2020-1472.

3.3 Панель управления Exchange

В сценарии почтовый сервер связан с Exchange ECP и CVE-2020-0688. Ошибки защиты Exchange могут приводить к выполнению кода в контексте веб-компонентов и размещению веб-шеллов. Microsoft описывает использование подобных файлов в разборе атак на серверы Exchange.

Веб-шелл — серверный файл, который принимает данные из HTTP-запроса и передаёт их механизму исполнения. Обнаруженный `AM_Backdoor.aspx` содержал вызов `eval` для входного параметра. Каталог размещения такого файла помогает определить область обследования, но не устанавливает конкретную первоначальную уязвимость.

4 Обнаружение и восстановление последовательности атаки

4.1 События на WordPress

В ViPNet IDS NS выделено событие от 28 октября в 16:10:29.897: `ET POLICY Executable and linking format (ELF) file download var1`. Код события — 3121915, уровень опасности высокий. Источник — `195.239.174.11:5563`, получатель — `10.10.1.22:58394`. Направление соответствует передаче данных от внешнего узла к веб-серверу.

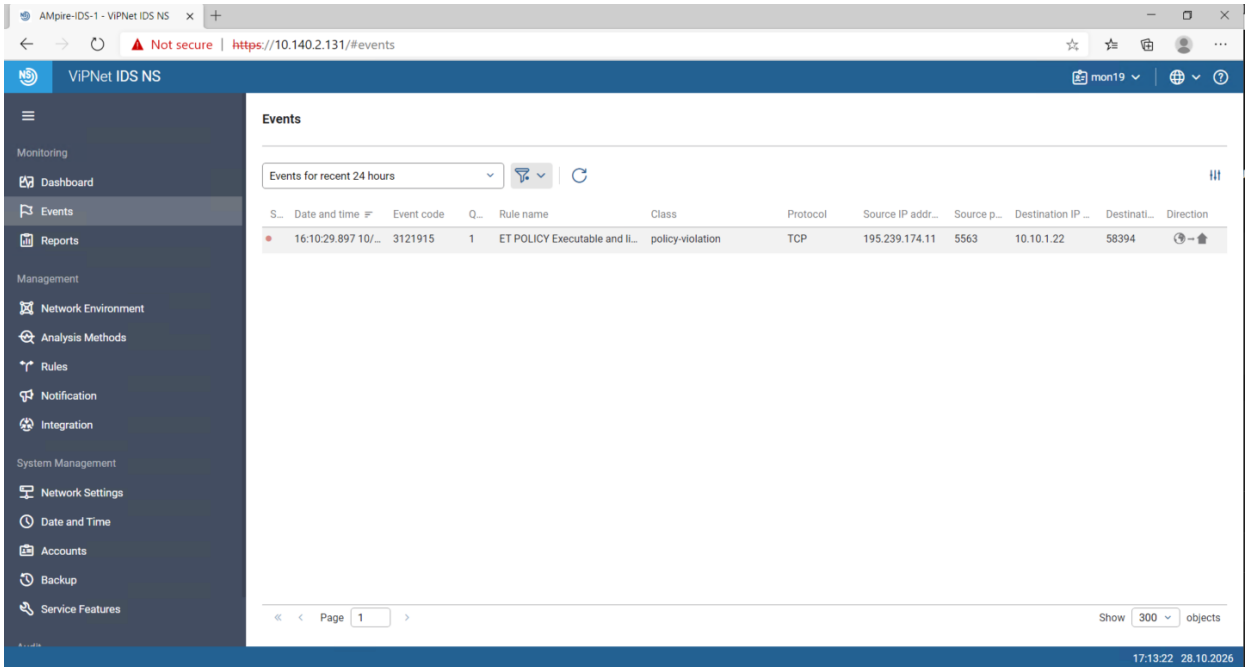


Рисунок 1 — Событие передачи ELF-файла на сервер WordPress

Карточка события уточняет классификацию `policy-violation`, протокол TCP и интерфейс регистрации eth2. Название сигнатуры указывает на обнаруженный формат содержимого, а не на доказанный путь его сохранения или запуск на сервере.

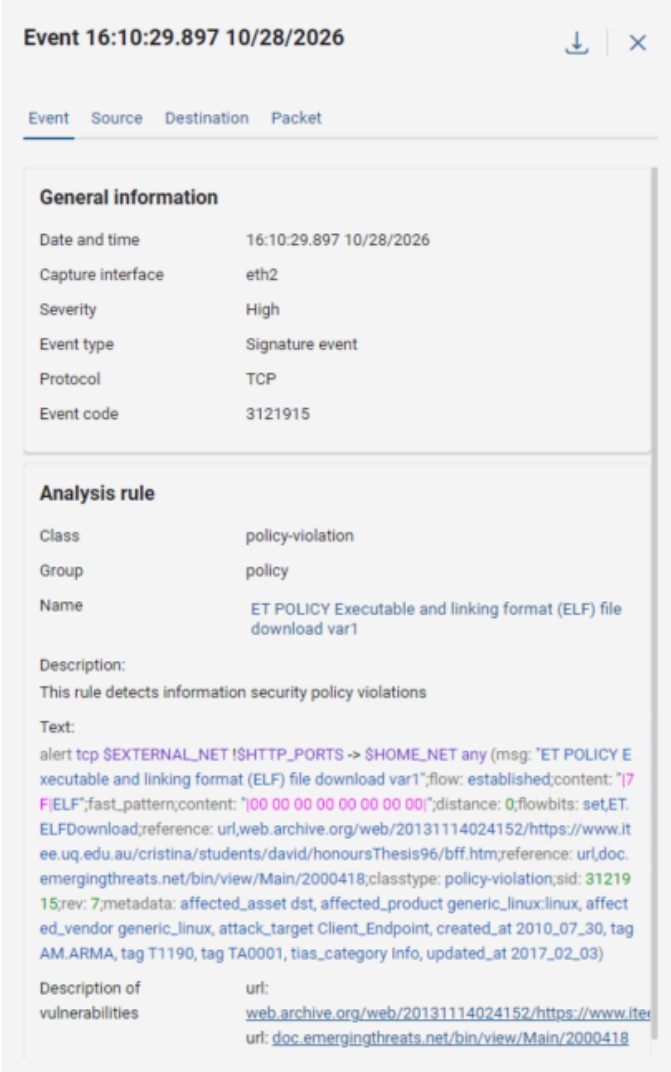


Рисунок 2 — Параметры и сигнатура события WordPress

Для события выгружен пакет. В доступном фрагменте длиной 1514 байт содержатся 1448 байт полезной нагрузки TCP, включая сигнатуру ELF `7F 45 4C 46`. Это подтверждает соответствие события содержимому пакета. Полного сеанса передачи и факта исполнения из одного пакета установить нельзя.

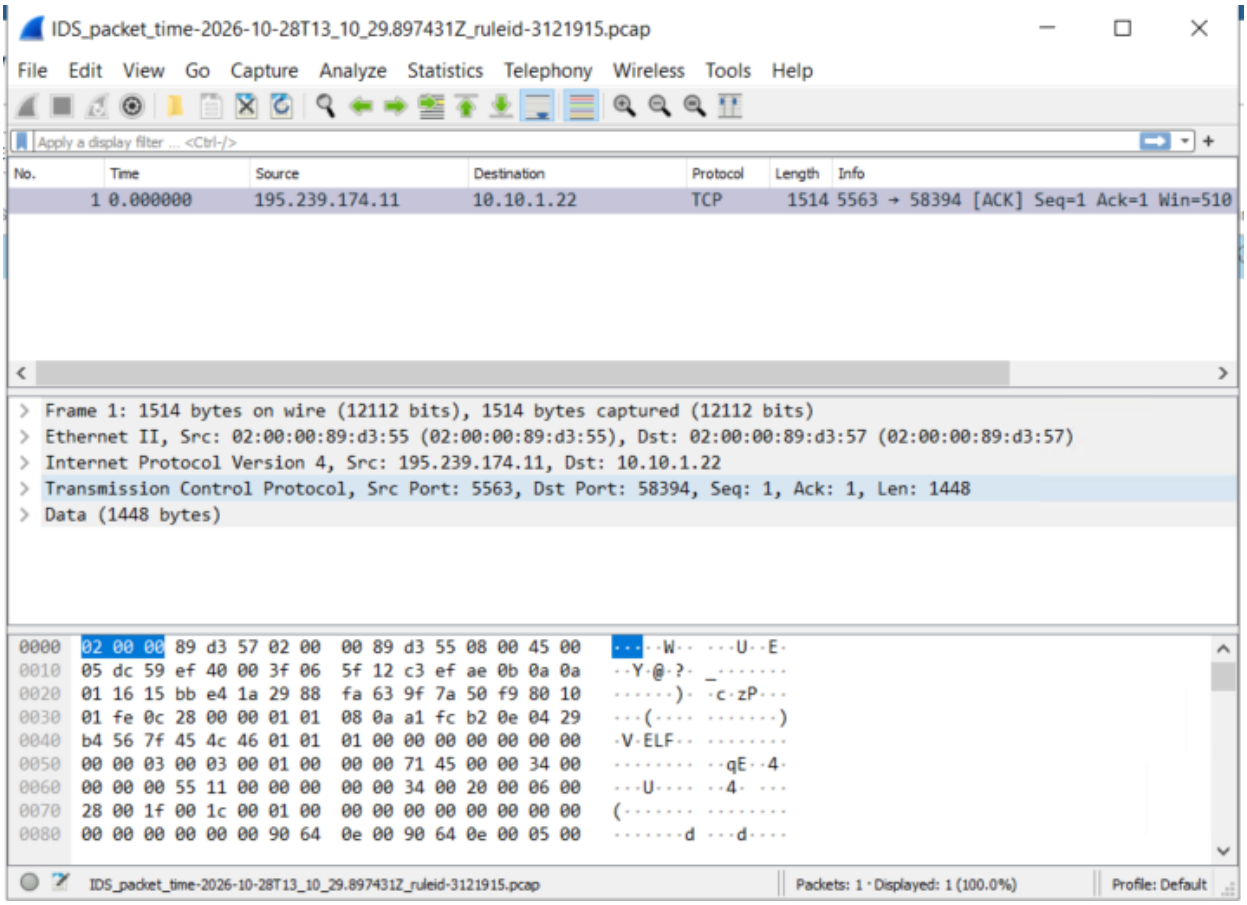


Рисунок 3 — Выгрузка сетевого пакета события WordPress

Время пакета 13:10:29 UTC согласуется с 16:10:29 в интерфейсе IDS при смещении UTC+3. Эта поправка далее использована при поиске изменённых файлов на Ubuntu.

4.2 События на контроллере домена

Следующий эпизод связан с соединением `10.10.1.22:38958 → 10.10.2.10:49666`. В 16:12:01.302 зарегистрирована первая фаза Zerologon — NetrServerReqChallenge. Затем наблюдаются события аутентификации с нулевыми значениями и в 16:12:01.555 — NetrServerAuthenticate3. Источником является скомпрометированный веб-сервер, а целью — контроллер домена.

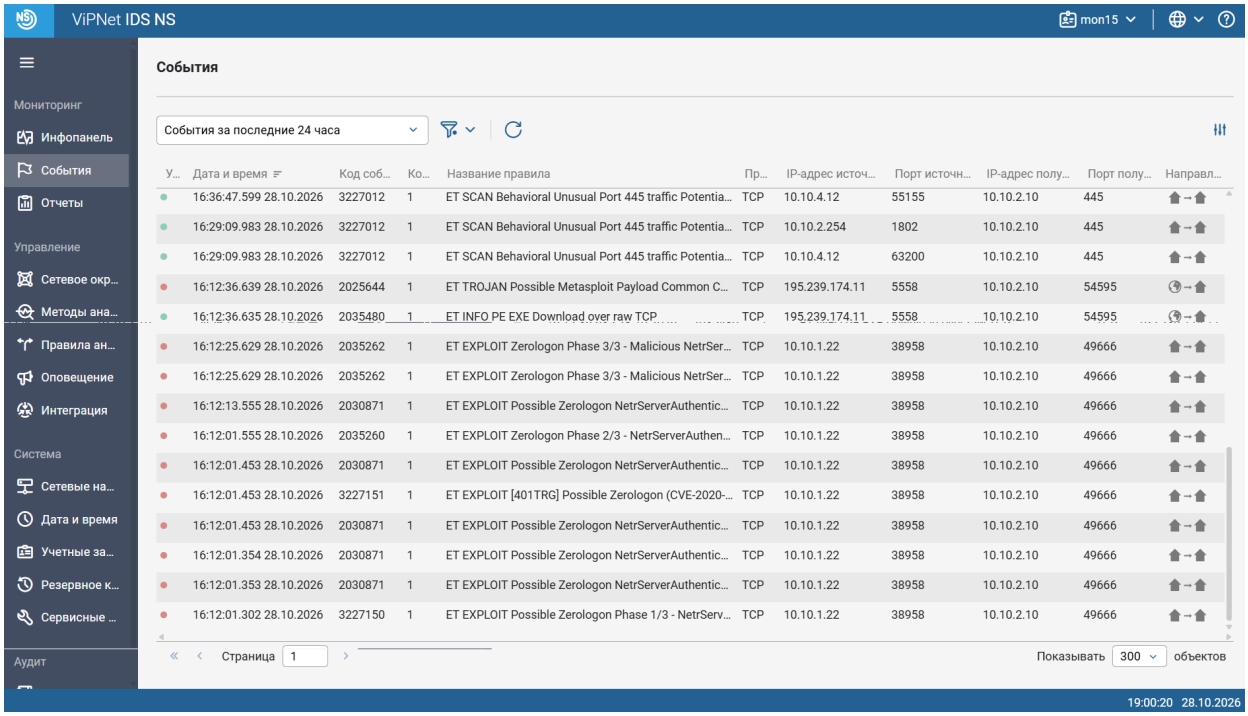


Рисунок 4 — Последовательность событий Zerologon в направлении AD

В 16:12:25.629 сформировано событие 2035262: `ET EXPLOIT Zerologon Phase3/3 - Malicious NetrServerPasswordSet2 (CVE-2020-1472)`. Категория — `attempted-admin`, уровень опасности высокий. Наличие связанной последовательности из трёх фаз делает эпизод более определённым, чем одиночное неспецифичное срабатывание.

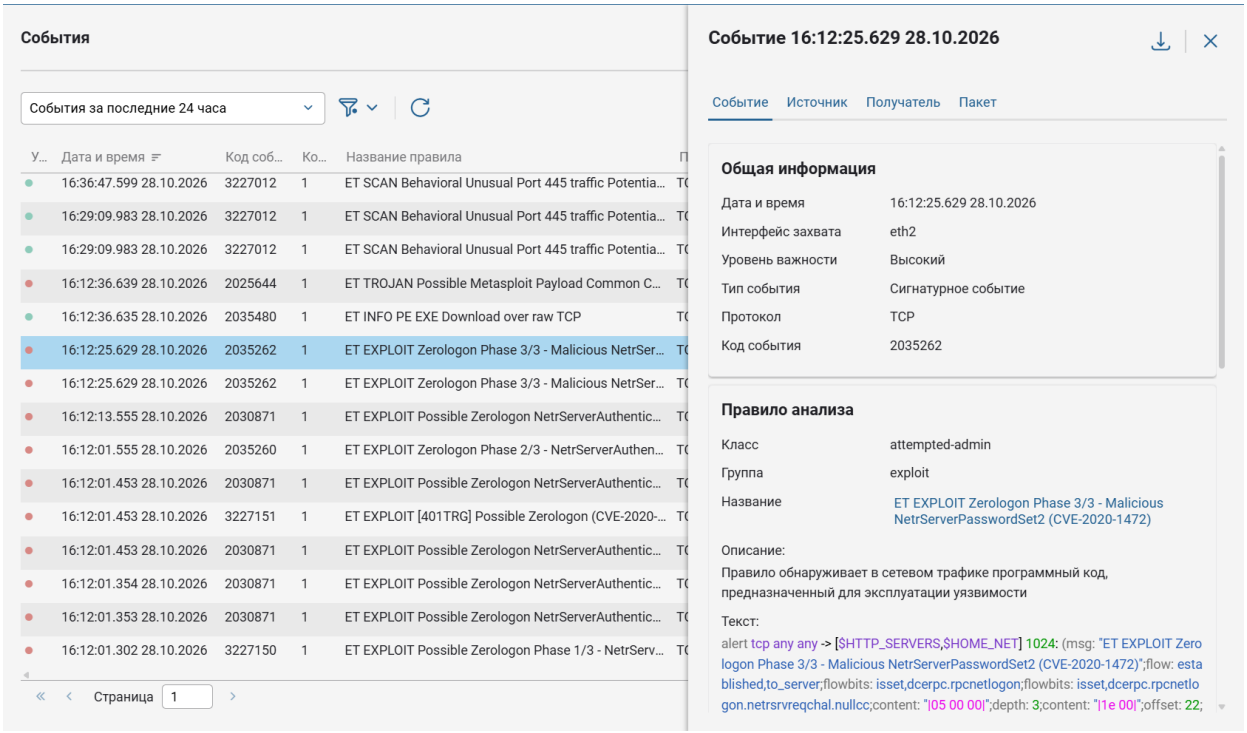


Рисунок 5 — Правило третьей фазы Zerologon и вызов смены пароля

Пакет третьей фазы имеет длину 690 байт, из них 624 байта — полезная нагрузка TCP с запросом DCE/RPC. Его время 13:12:25.629 UTC соответствует времени IDS. Один запрос подтверждает передачу соответствующего вызова, но не заменяет ответ сервера и проверку результата изменения пароля.

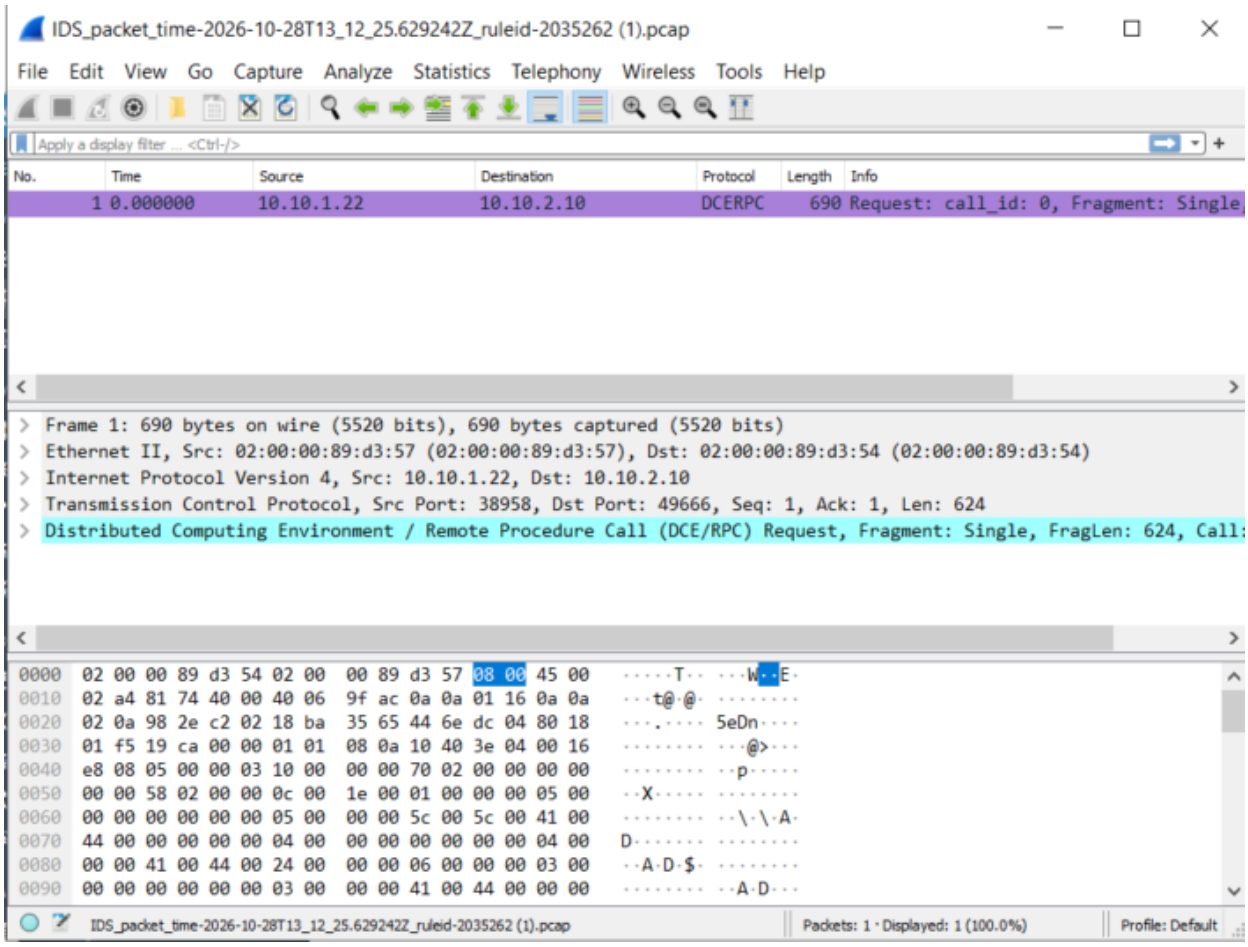


Рисунок 6 — Выгрузка пакета DCE/RPC для события Zerologon

В 16:12:36.635 и 16:12:36.639 далее зарегистрированы загрузка PE EXE и сигнатура возможной полезной нагрузки Metasploit. Для этого соединения источник — `195.239.174.11:5558`, получатель — `10.10.2.10:54595`. Найденный позднее Python-процесс стартовал в 16:12:52, что связывает сетевой эпизод и обследование контроллера по времени.

4.3 События на Exchange

На почтовом сервере наблюдаются две группы загрузок исполняемого содержимого: в 16:13:19.527–16:13:19.531 и 16:13:33.352–16:13:33.363. Соединения приходят с `195.239.174.11`, порты источника 5561 и 5564; адрес назначения — `10.10.2.11`, порты 10008 и 10055.

У...	Дата и время	Код события	Ко...	Название правила	Протокол	IP-адрес источника	Порт исто...	IP-адрес получате...	Порт полу...	Направл...
●	16:13:33.363 28.10.2...	2025644	1	ET TROJAN Possible Metasploit P...	TCP	195.239.174.11	5564	10.10.2.11	10055	→🏠
●	16:13:33.352 28.10.2...	2035480	1	ET INFO PE EXE Download over ra...	TCP	195.239.174.11	5564	10.10.2.11	10055	→🏠
●	16:13:19.531 28.10.2...	2025644	1	ET TROJAN Possible Metasploit P...	TCP	195.239.174.11	5561	10.10.2.11	10008	→🏠
●	16:13:19.527 28.10.2...	2035480	1	ET INFO PE EXE Download over ra...	TCP	195.239.174.11	5561	10.10.2.11	10008	→🏠

Рисунок 7 — События передачи исполняемого содержимого на Exchange

Правило `ET TROJAN Possible Metasploit Payload Common Construct Bind_API (from server)`, код 2025644, указывает на узнаваемую конструкцию в передаваемых данных. Сиг-

натура помогает выделить подозрительную загрузку, но не даёт имени сохранённого файла на целевой системе.

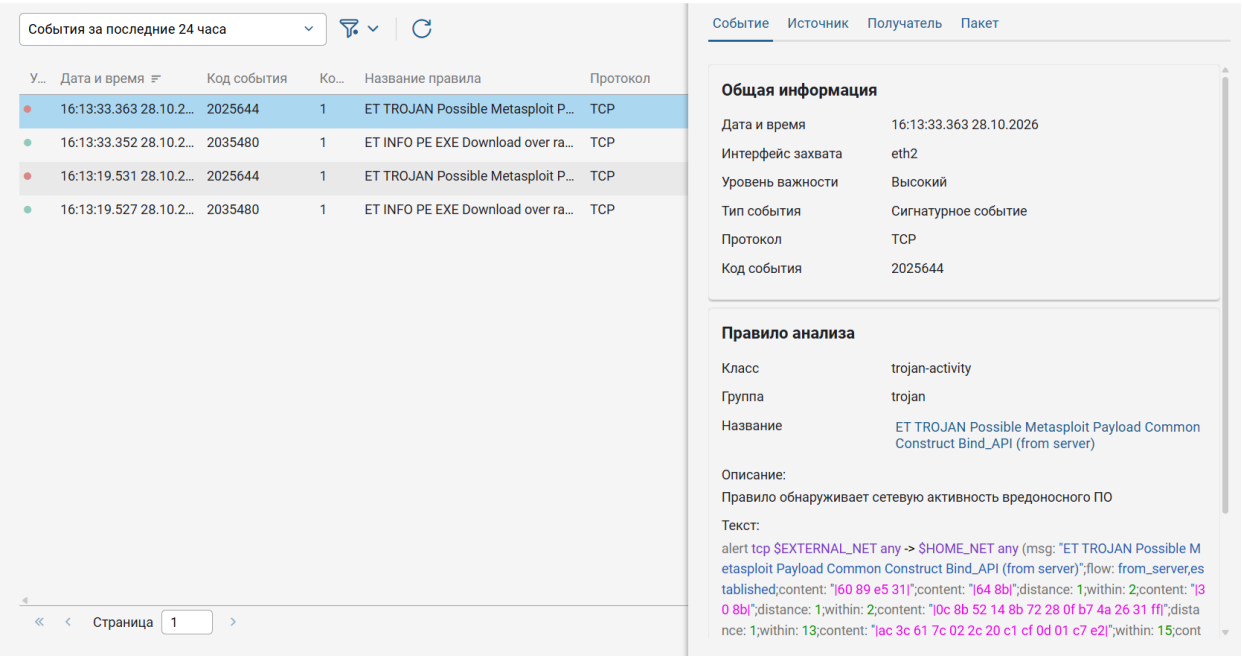


Рисунок 8 — Описание сигнатуры возможной полезной нагрузки Metasploit

Отдельно в 16:13:19.211 зарегистрирован исходящий запрос `10.10.2.11:10007 → 195.239.174.11:8010`. С ним связаны правила загрузки PS1 и обнаружения загрузчика JTTH. По времени этот запрос предшествует первой из показанных загрузок PE; последовательность устанавливается по меткам времени, а не по порядку строк на экране.

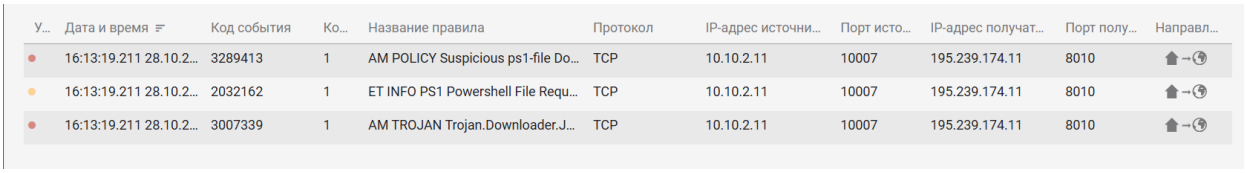


Рисунок 9 — Исходящий запрос Exchange к внешнему серверу на порту 8010

Содержимое правила включает признаки HTTP-запроса GET к ресурсу с расширением `.ps1`. Такая комбинация направления соединения и типа запрашиваемого файла требует проверки последующего выполнения PowerShell и состояния веб-компонентов Exchange.

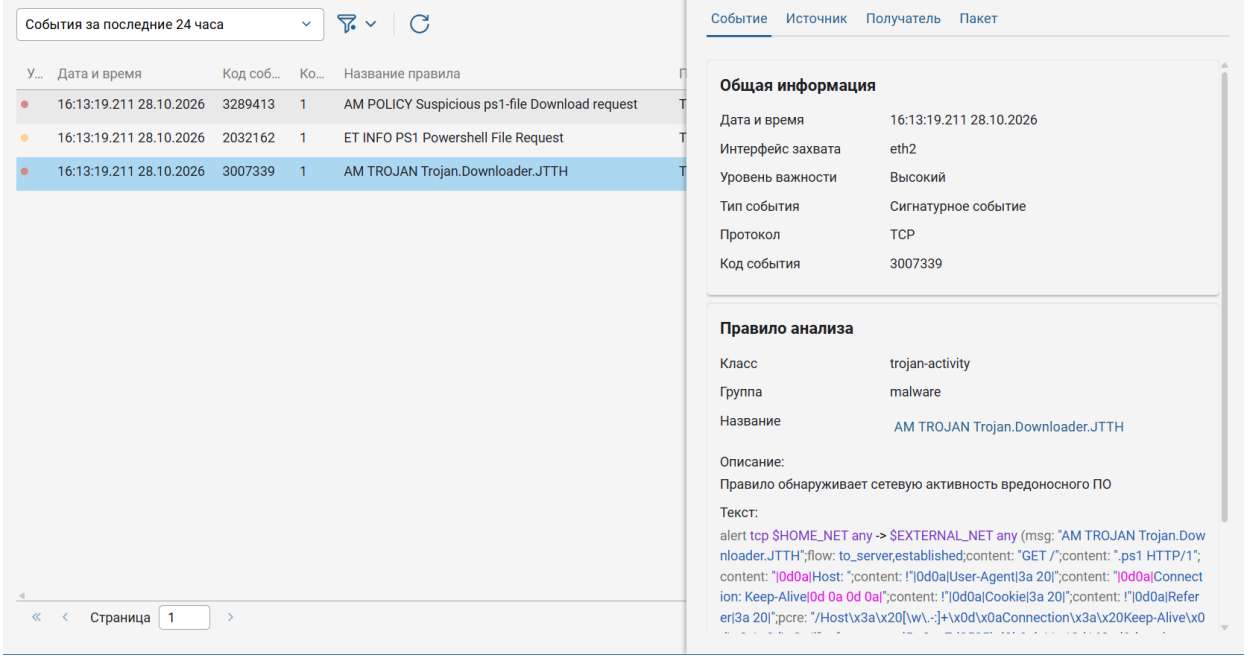


Рисунок 10 — Сигнатура загрузчика, связанная с запросом PS1

Результаты сетевого анализа определили порядок обследования: сначала веб-сервер, затем доменная инфраструктура и почтовый узел. Подтверждение закрепления получено уже при проверке файлов и процессов.

4.4 Хронология

Хронология основных событий представлена ниже (таблица 2). Время приведено для 28 октября 2026 года, UTC+3. Файловые отметки Ubuntu переведены из UTC; для Windows использованы отметки, показанные на скриншотах стенда.

Таблица 2 — Хронология обнаруженной активности

Время	Событие	Значение для расследования
16:10:29.897	ELF-трафик Kali → WordPress	Первая выделенная сетевая активность против сайта
Около 16:10	Изменение изображения и debug.log на WordPress	Сопоставление сетевого эпизода с файловыми изменениями
16:12:01.302–16:12:25.629	Три фазы Zerologon WordPress → AD	Признаки продвижения из веб-сегмента к домену
16:12:36.635–16:12:36.639	PE EXE и Metasploit, Kali → AD	Загрузка подозрительного исполняемого содержимого
16:12:52	Старт Python-процесса на AD	Работа обнаруженного средства закрепления
16:13:19.211	Exchange → Kali, запрос PS1	Исходящее обращение к внешнему загрузчику
16:13:19.527–16:13:33.363	PE EXE и Metasploit, Kali → Exchange	Два последовательных эпизода передачи полезной нагрузки
16:13:44	Изменение AM_Backdoor.aspx	Файловый артефакт компрометации Exchange

Связь WordPress → AD подтверждается адресами сетевого соединения. Для Exchange установлены обращения к тому же внешнему узлу и близкое время событий. Полная причинная связь всех действий потребовала бы журналов аутентификации, выполнения процессов и полного сетевого обмена; доступные материалы позволяют восстановить наблюдаемую последовательность, сохраняя эти границы вывода.

5 Расследование и восстановление WordPress

5.1 Веб-корень и время

Подключение к `10.10.1.22` подтвердило имя узла web-portal-3 и Ubuntu 18.04.5 LTS. Проверены серверное время, процессы Apache и расположение сайта. Это позволило выполнять поиск в фактическом веб-корне и избежать смешения времени ОС с отображением IDS.

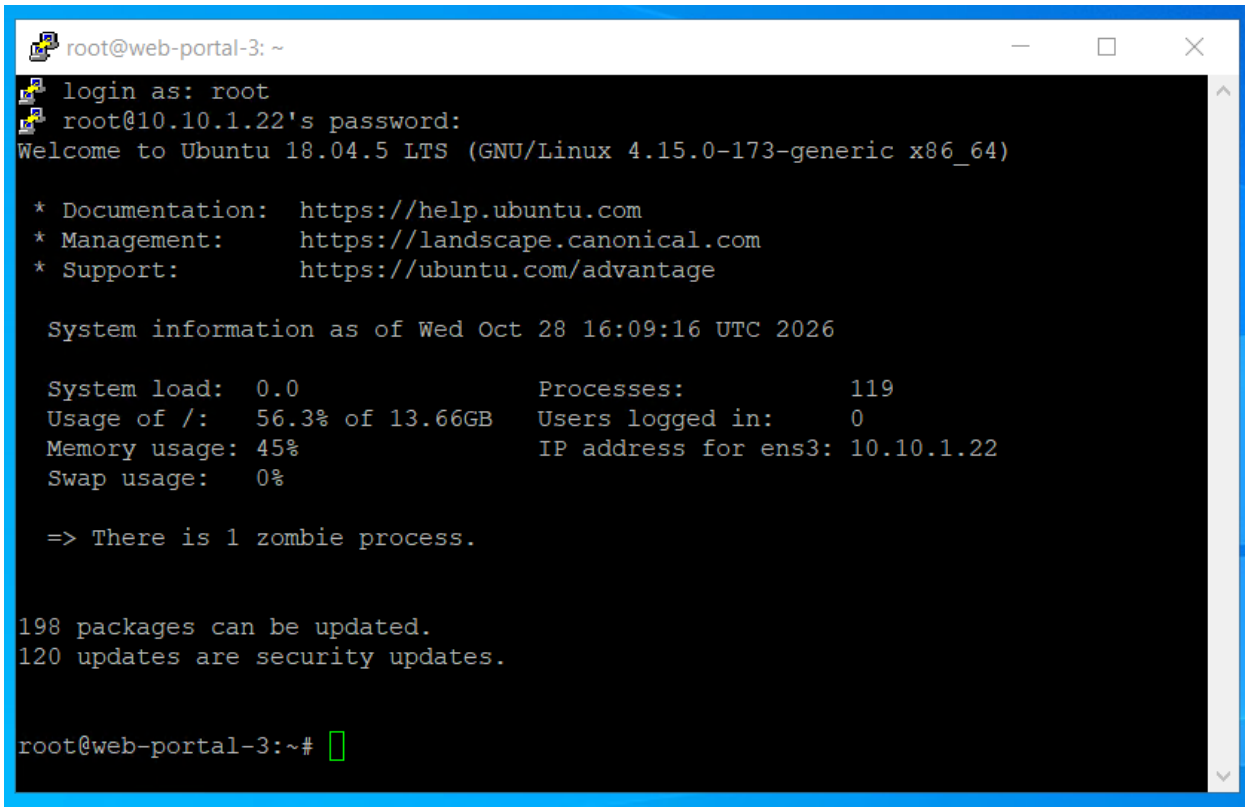


Рисунок 11 — Подключение к серверу WordPress и сведения об ОС

Первоначальный поиск по времени после 15:50 не дал нужных файлов: ОС показывала UTC. После перехода к границе 13:00 обнаружены изменения `sitesecure-1.jpeg` и `wp-content/debug.log` около 13:10. По времени они совпадают с эпизодом 16:10 в IDS. В дальнейшем путь `/var/www/html/wordpress` использовался как исходная область файлового обследования.

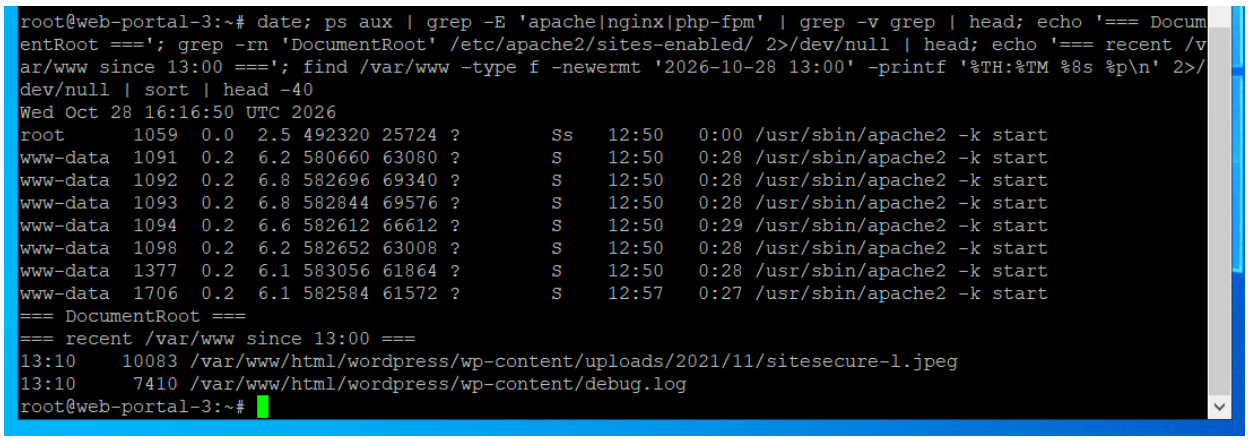


Рисунок 12 — Проверка веб-корня и файловых изменений с поправкой времени

Согласование часовых поясов стало необходимым условием корректного поиска артефактов, а не самостоятельным доказательством их вредоносности.

5.2 Подменённое изображение

В каталоге `wp-content/uploads/2021/11` обнаружен файл `sitesecure-1.jpeg` размером 10083 байта с отметкой изменения в период атаки. Рядом находилась резервная копия `.bak`. Проверка формата показала, что текущий файл являлся PNG 1200 × 630, несмотря на расширение JPEG. Резервная копия представляла JPEG 1024 × 768 размером 136133 байта.

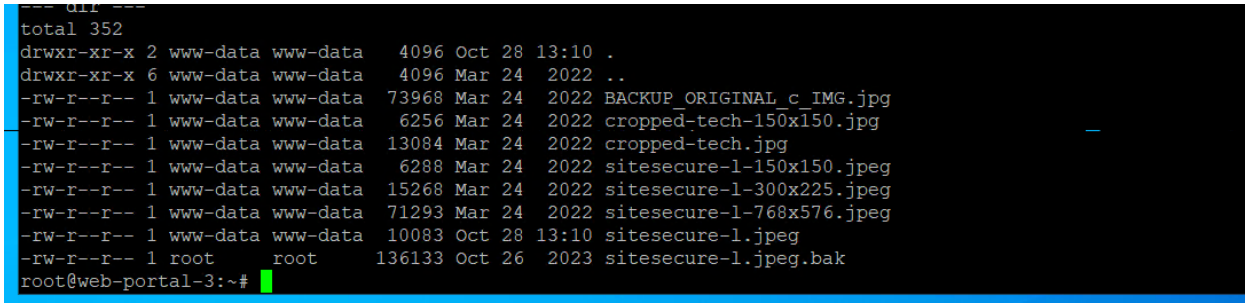


Рисунок 13 — Изображение сайта и резервная копия в каталоге загрузок

Поиск признака `<?php` в изменённом изображении не дал совпадений. Эта проверка исключила только обнаружение указанной строки; она не является универсальным анализом безопасности файла. Основным основанием восстановления стали различие содержимого и наличие исходного изображения в резервной копии.

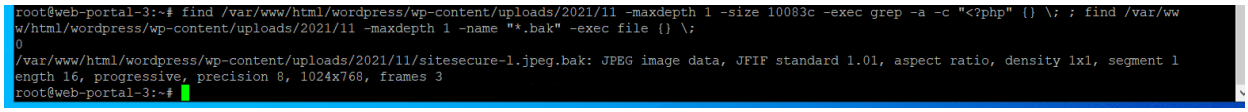


Рисунок 14 — Проверка изменённого файла изображения

Для выбора фактического пути использован результат `find`, после чего исходное изображение скопировано поверх изменённого файла с сохранением атрибутов:

```
cd /var/www/html/wordpress/wp-content/uploads/2021/11
t=$(find . -maxdepth 1 -size 10083c)
cp -p ./*.bak "$t"
ls -la "$t"
file "$t"
```

Повторная проверка показала JPEG размером 136133 байта, 1024 × 768. Таким образом, восстановление подтверждено изменением фактического формата и размера, а позднее — видом главной страницы.

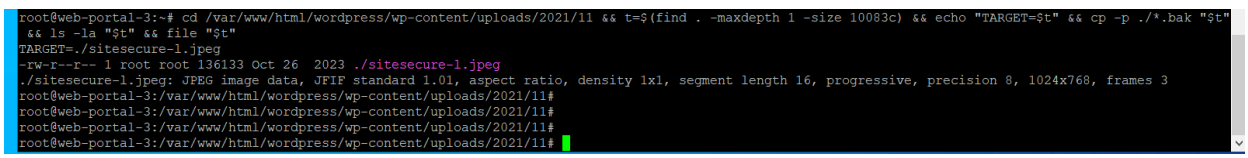


Рисунок 15 — Восстановленное изображение в исходном формате JPEG

5.3 Вредоносные плагины

В каталоге плагинов присутствовали обычные компоненты CMS и два каталога с нетипичными именами: `SpZgSotVRf` и `HAILxWWVK`. Проверялись их состав, размеры и содержимое PHP-файлов. Имя каталога само по себе не использовалось как достаточное основание удаления.



Рисунок 16 — Состав каталога плагинов WordPress

Каждый подозрительный каталог содержал небольшой файл с заголовком плагина и отдельную полезную нагрузку. В `SpZgSotVRf` найден `tcpFjmMsfA.php` размером 1114 байт; в `HAILxWWVK` — `IeuEytDPbu.php` размером 1113 байт. Это два каталога с двумя бэкдорами, а не четыре независимых веб-шелла по числу всех файлов.

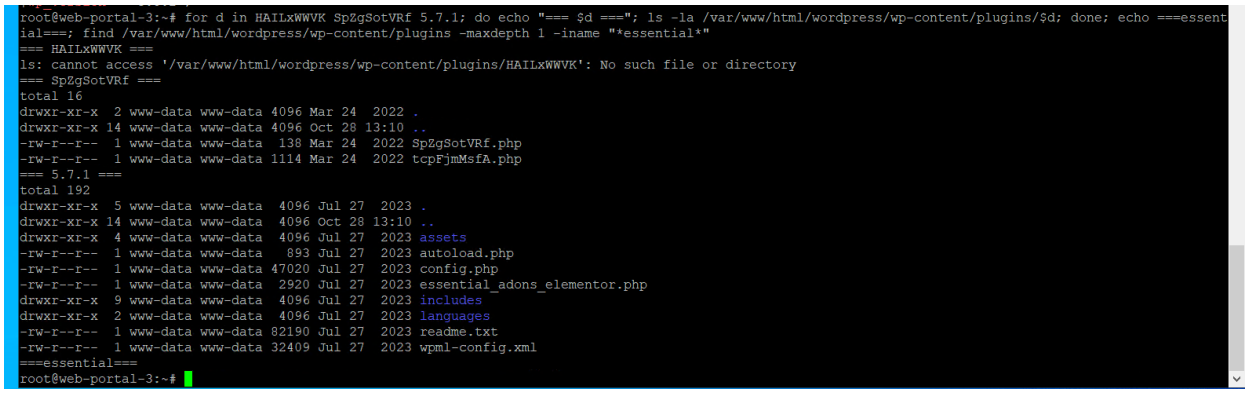


Рисунок 17 — Проверка подозрительного плагина и состава Essential Addons

В содержимом первого бэкдора обнаружены средства создания обратного соединения и адрес `185.88.181.55:4444`. Этот адрес является статическим индикатором из файла. В представленных событиях 28 октября не подтверждено активное соединение с ним, поэтому он не отождествляется с внешним узлом `195.239.174.11`.

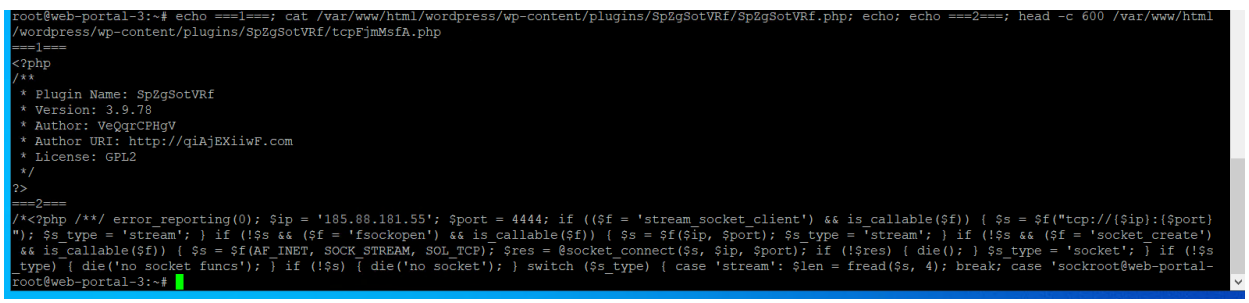


Рисунок 18 — Просмотр кода PHP-бэкдора в каталоге плагина

Каталог `SpZgSotVRf` перемещён из веб-корня в `/root/SpZgSotVRf_removed`. Такой способ вывел код из доступного Apache каталога и сохранил материал для последующего анализа.



Рисунок 19 — Первый вредоносный плагин выведен из веб-каталога

Проверка второго каталога подтвердила наличие отдельной PHP-нагрузки. Для него выполнено аналогичное перемещение в `/root/HAILxWWVK_removed`.

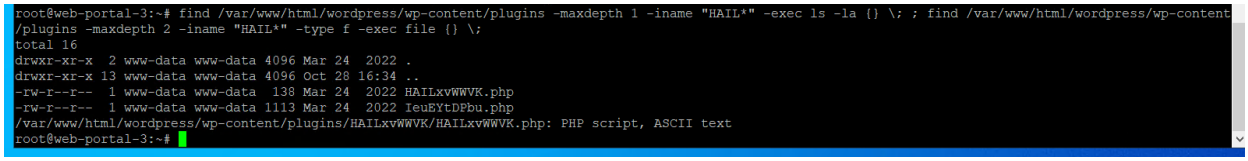


Рисунок 20 — Проверка полезной нагрузки второго подозрительного плагина

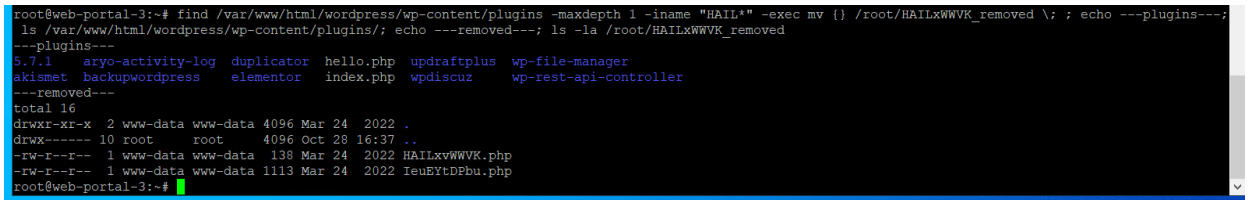


Рисунок 21 — Второй вредоносный плагин перемещён в карантин

После этих действий оба обнаруженных каталога плагинов отсутствовали в исходном веб-пути. Для восстановления доверия ко всей CMS дополнительно необходима сверка остальных компонентов с эталонными дистрибутивами.

5.4 PHP-файлы в uploads

Каталог `uploads` предназначен для пользовательских медиафайлов; размещение в нём исполняемых PHP-файлов потребовало отдельной проверки. В `uploads/2022/03` обнаружены 37 файлов размером около 1115 байт. В одном из образцов присутствовали строка `GIF8`, PHP-код обратного подключения и адрес `10.10.1.23:5764`.

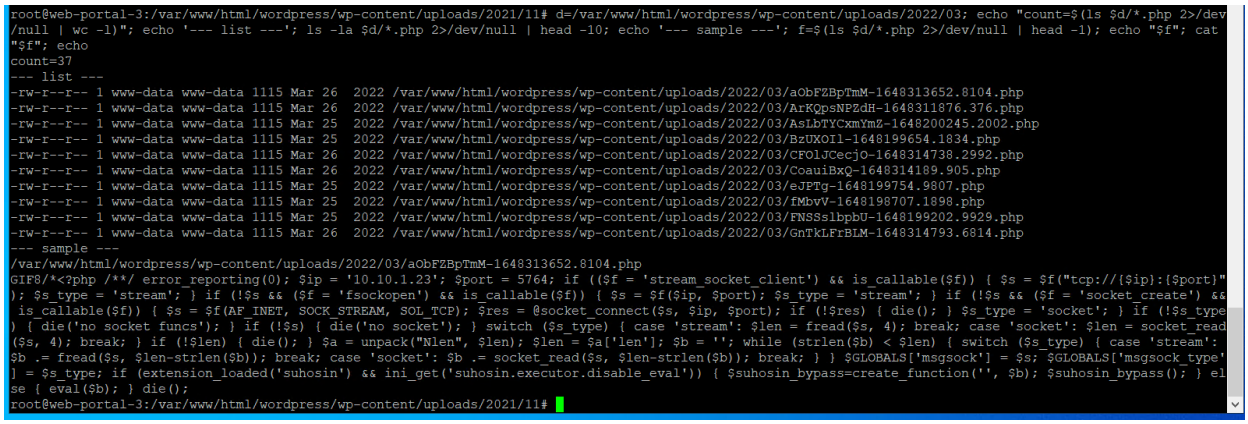


Рисунок 22 — Обнаружение PHP-файлов в каталоге uploads за март 2022 года

Эти файлы перемещены в `/root/wp_shells_uploads`. После первой операции в проверенном каталоге осталось ноль PHP-файлов, а в карантине находилось 37. Подсчёт фиксировал результат конкретного этапа, поэтому затем поиск расширен на всё дерево uploads.

```
root@web-portal-3:/var/www/html/wordpress/wp-content/uploads/2021/11# mkdi
/03 -maxdepth 1 -name "*.php" -exec mv {} /root/wp_shells_uploads/ \; ; ec
 2>/dev/null | wc -l)"; echo "moved: $(ls /root/wp_shells_uploads | wc -l)
left in uploads: 0
moved: 37
root@web-portal-3:/var/www/html/wordpress/wp-content/uploads/2021/11#
```

Рисунок 23 — Результат перемещения первых 37 PHP-файлов

Проверка всей структуры загрузок включала рекурсивный поиск по расширению. Это выявило, что очистка одного месяца не покрывает остальные подкаталоги.

```
root@web-portal-3:/var/www/html/wordpress/wp-content/uploads/2021/11# echo
*.php' | wc -l; echo '--- changed since 13:00 ---'; find /var/www/html/word
d -25
--- php in uploads ---
16
--- changed since 13:00 ---
13:10     7410 /var/www/html/wordpress/wp-content/debug.log
root@web-portal-3:/var/www/html/wordpress/wp-content/uploads/2021/11#
```

Рисунок 24 — Расширение контрольного поиска на дерево uploads

В `uploads/2022/01` оставались ещё 16 PHP-файлов: 13 размером 1115 байт и три размером 2139 байт. Один из крупных файлов содержал запуск `/bin/sh -i`, использование `pcntl_fork` и обратный адрес `10.10.1.23:5555`.

```
root@web-portal-3:/var/www/html/wordpress/wp-content/uploads/2021/11# find /var/www/html/wordpress/
n" | sort
10:13     1115 /var/www/html/wordpress/wp-content/uploads/2022/01/cwulbZTAr-1642424957.4071.php
10:13     1115 /var/www/html/wordpress/wp-content/uploads/2022/01/EOtwV-1641909469.2608.php
10:13     1115 /var/www/html/wordpress/wp-content/uploads/2022/01/fnYvIqL-1642590561.803.php
10:13     1115 /var/www/html/wordpress/wp-content/uploads/2022/01/LEciDMtCC-1642417287.4346.php
10:13     1115 /var/www/html/wordpress/wp-content/uploads/2022/01/MMfLoNNpKKNv-1642425719.4285.php
10:13     1115 /var/www/html/wordpress/wp-content/uploads/2022/01/MxnpLJrVV-1642585175.4809.php
10:13     1115 /var/www/html/wordpress/wp-content/uploads/2022/01/nUkLUVkOl-1642588993.0407.php
10:13     1115 /var/www/html/wordpress/wp-content/uploads/2022/01/nxGMW-1642416839.4433.php
10:13     1115 /var/www/html/wordpress/wp-content/uploads/2022/01/PcLCpcJDQn-1642584712.7264.php
10:13     1115 /var/www/html/wordpress/wp-content/uploads/2022/01/qnHCui-1642592029.3202.php
10:13     1115 /var/www/html/wordpress/wp-content/uploads/2022/01/SYWTroBvfR-1642361832.5955.php
10:13     1115 /var/www/html/wordpress/wp-content/uploads/2022/01/vbFrkfLglFX-1642584741.886.php
10:13     1115 /var/www/html/wordpress/wp-content/uploads/2022/01/VSzJFDhn-1642592123.1213.php
10:13     2139 /var/www/html/wordpress/wp-content/uploads/2022/01/1-1642423075.8899.php
10:13     2139 /var/www/html/wordpress/wp-content/uploads/2022/01/1-1642423454.2146.php
10:13     2139 /var/www/html/wordpress/wp-content/uploads/2022/01/1-1642424192.5119.php
root@web-portal-3:/var/www/html/wordpress/wp-content/uploads/2021/11#
```

Рисунок 25 — Оставшиеся PHP-файлы в январском подкаталоге

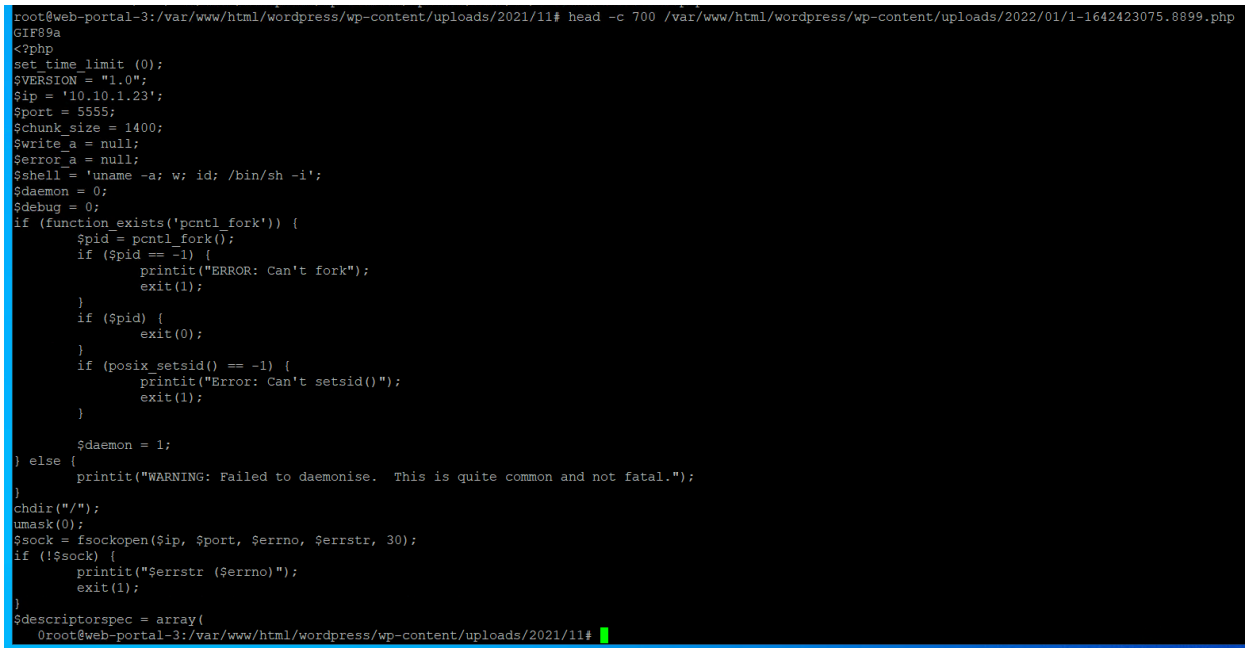


Рисунок 26 — Код обратного PHP-подключения в файле размером 2139 байт

После перемещения оставшихся файлов итоговый подсчёт показал: PHP-файлов в uploads — 0, файлов в карантине — 53. Значение соответствует двум этапам очистки: 37 + 16. Адреса из старых файлов сохранены как индикаторы для проверки журналов; их фактическое использование в текущей атаке не установлено.

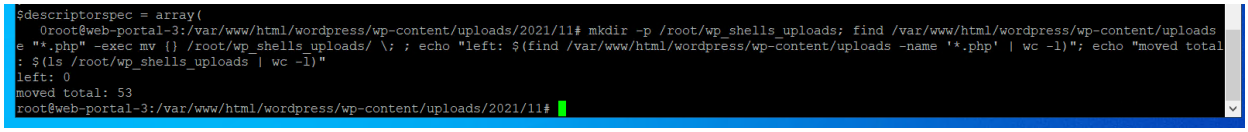


Рисунок 27 — Итоговая проверка: в uploads нет PHP-файлов, в карантине их 53

5.5 Отключение плагина и проверка сайта

В компоненте Essential Addons определена версия 5.7.1. Вместо установки новой версии каталог перемещён из `wp-content/plugins` в `/root/essential-addons-5.7.1_removed`. Следовательно, выполненное действие следует считать отключением уязвимого компонента. Обновление плагина и всей CMS в материалах не подтверждено.

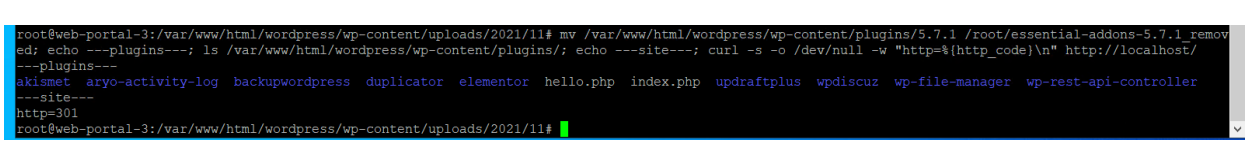


Рисунок 28 — Отключение компонента Essential Addons версии 5.7.1

Локальный HTTP-запрос вернул перенаправление 301, что подтверждает ответ веб-сервера, но не полноту работы сайта. После этого страница проверена в браузере: ресурс открывался с переходом на `webportal.ampire.corp`, отображались название JSC “TOP PRO” и восстановленное изображение красного грузовика.

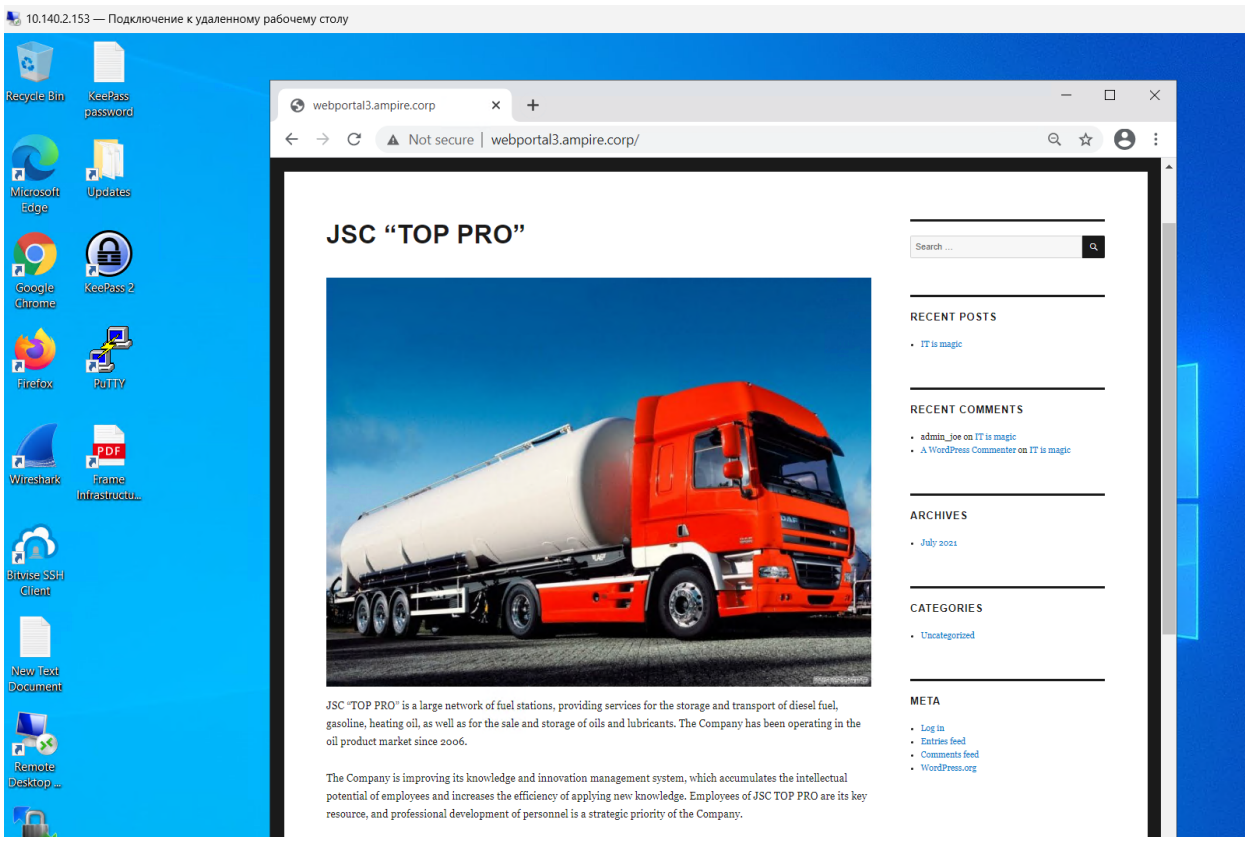


Рисунок 29 — Главная страница WordPress после восстановления

В результате восстановлено видимое содержимое сайта, два обнаруженных плагина и 53 PHP-файла выведены из веб-каталогов, Essential Addons отключён. Полный запрет исполнения PHP в uploads и изменение параметров редактирования файлов CMS в ходе работы не зафиксированы; эти меры остаются последующим усилением защиты.

6 Расследование на контроллере домена

6.1 Поиск бэкдора

На контроллере домена обнаружены несколько процессов Python. Проверка командных строк позволила отличить служебные скрипты стенда от процесса с файлом в пользовательском временном каталоге. Массовое завершение всех Python-процессов не выполнялось.

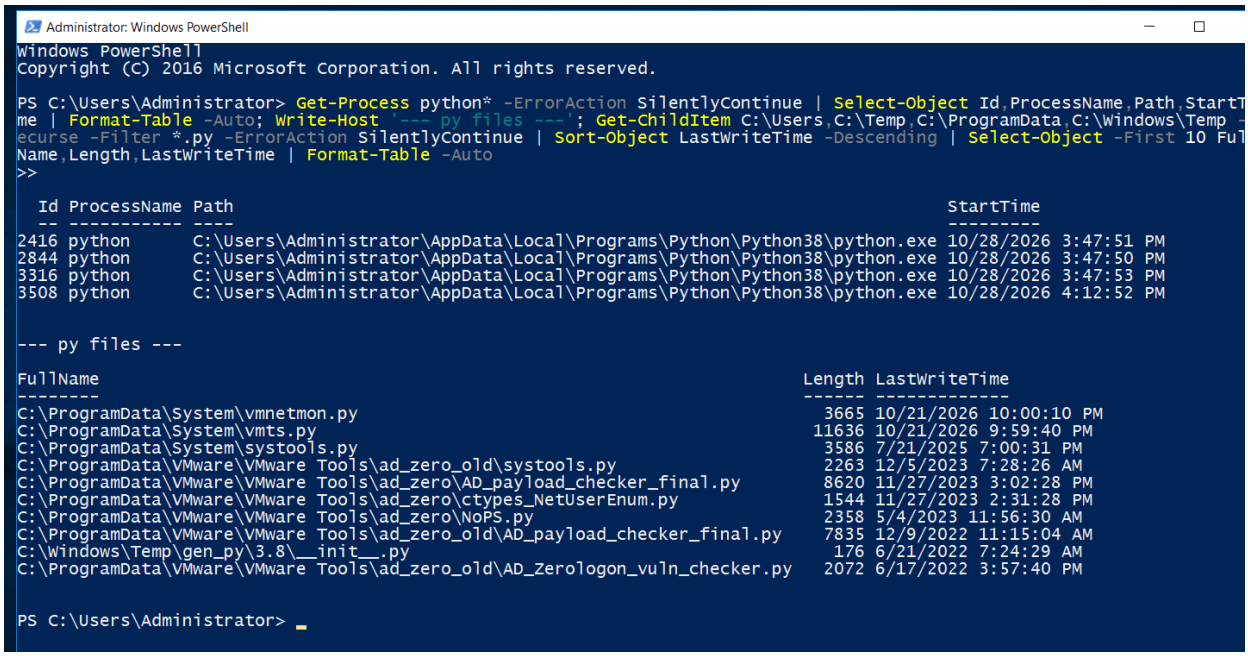


Рисунок 30 — Поиск процессов и Python-файлов на контроллере домена

PID 3508 был запущен в 16:12:52 и использовал файл `python_backdoor.py` с аргументами `195.239.174.11 5559`. Полный путь обнаруженного файла:

```
C:/Users/Administrator/AppData/Local/Temp/python_backdoor.py
```

Адрес совпадает с внешним узлом сетевых эпизодов. Остальные рассмотренные процессы запускали скрипты из `C:\ProgramData\System`, поэтому проверялись по содержимому командной строки, а не по одному имени интерпретатора.

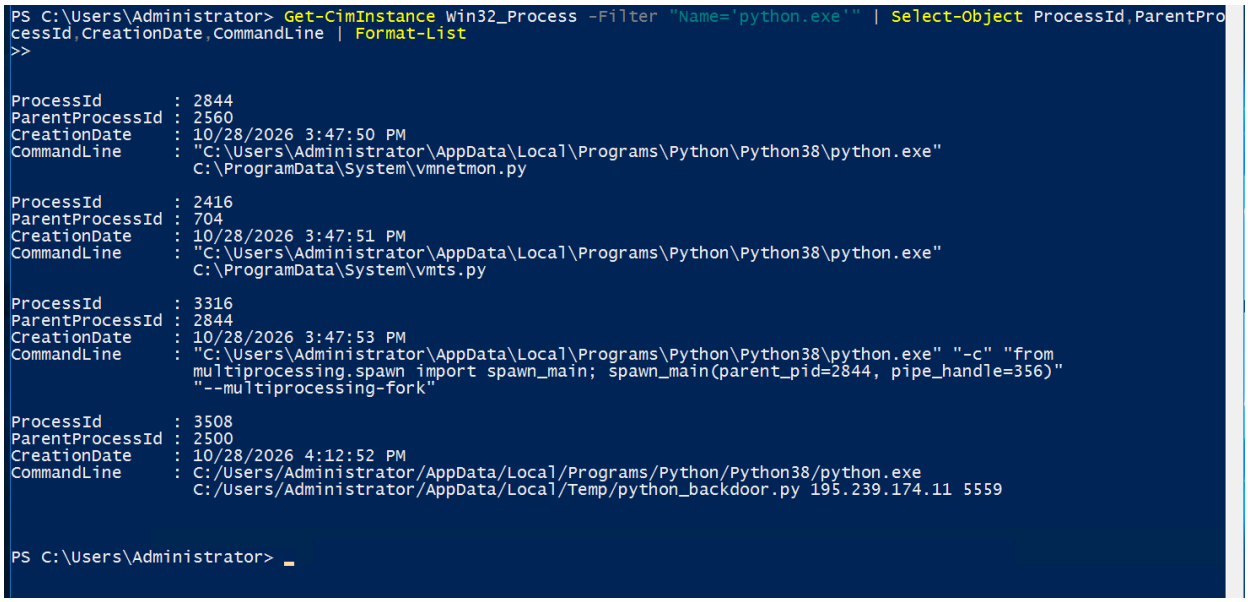


Рисунок 31 — Командная строка процесса PID 3508 с адресом внешнего узла

Проверка `Get-NetTCPConnection` для PID 3508 не вернула строк. Это означает отсутствие соединений, показанных данной командой в момент проверки. Из пустого вывода нельзя установить, ожидал ли процесс переподключения или уже завершил сетевую активность.

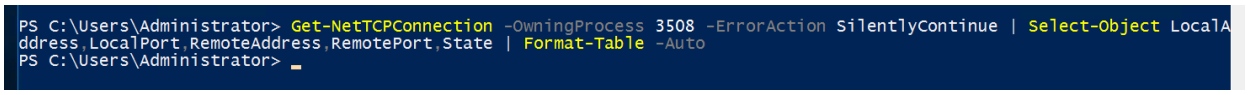


Рисунок 32 — Проверка соединений обнаруженного Python-процесса

Сочетание временного пути, внешнего адреса, времени старта и записи автозапуска стало основанием для удаления именно этого средства закрепления.

6.2 Удаление закрепления

Процесс 3508 остановлен, файл `python_backdoor.py` удалён. Повторная проверка не обнаружила процесс, а `Test-Path` для указанного файла вернул `False`.

```
Stop-Process -Id 3508 -Force
Remove-Item 'C:\Users\Administrator\AppData\Local\Temp\python_backdoor.py' -Force
Test-Path 'C:\Users\Administrator\AppData\Local\Temp\python_backdoor.py'
```

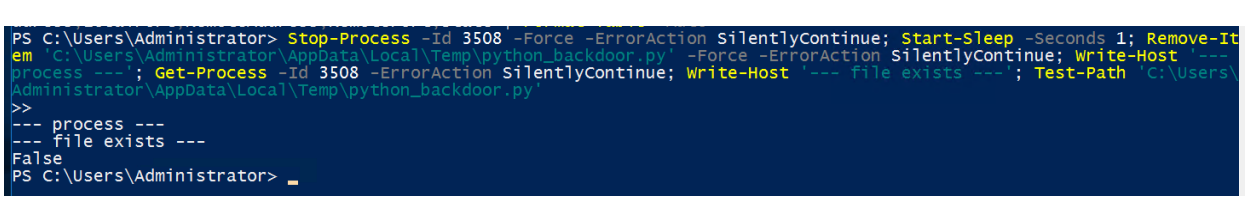


Рисунок 33 — Подтверждение удаления процесса и файла Python-бэкдора

В системном разделе автозапуска Run обнаружена запись `hacker_backdoor`. Полный путь раздела:

```
HKLM\Software\Microsoft\Windows\CurrentVersion\Run
```

Запись указывала на тот же Python-файл и внешний адрес с портом 5559. Таким образом, установлен отдельный механизм повторного запуска при входе пользователя.

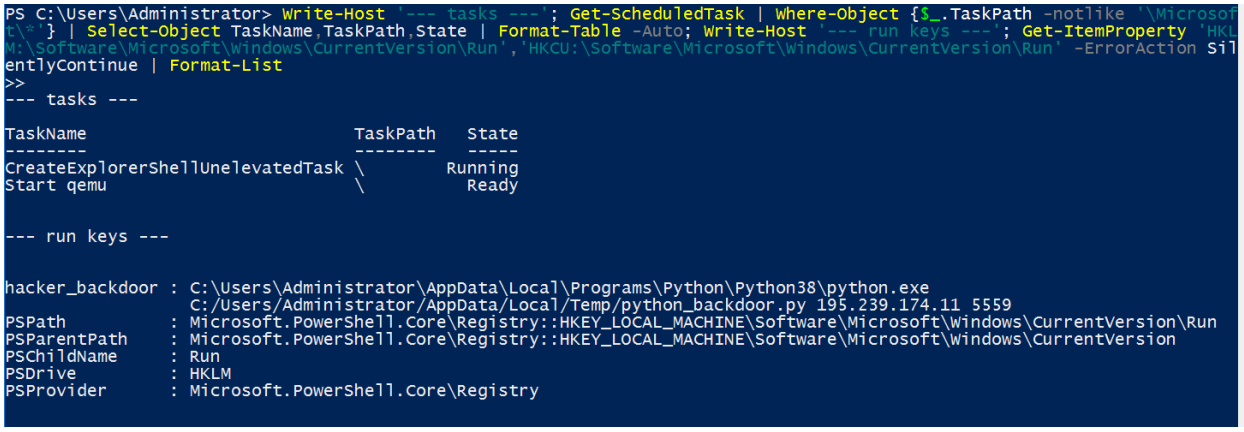


Рисунок 34 — Запись hacker_backdoor в системном разделе автозапуска

Запись удалена командой `Remove-ItemProperty`; повторный просмотр не показал её в разделе Run. Проверка охватила обнаруженный механизм автозапуска, но не заменяла полный аудит задач планировщика, служб и других точек закрепления.

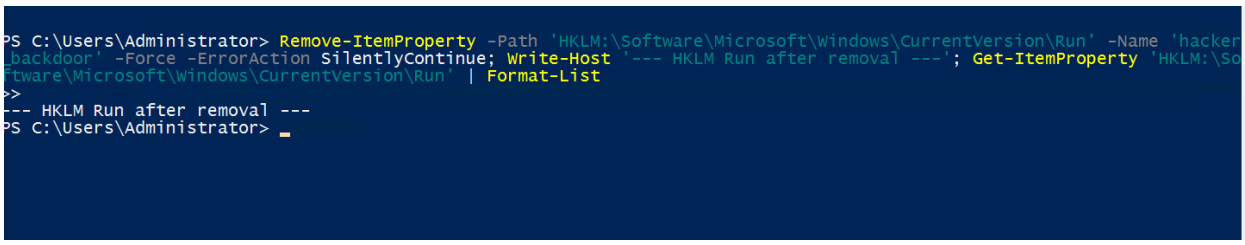


Рисунок 35 — Раздел Run после удаления записи бэкдора

6.3 Защита Netlogon

В разделе `HKLM\SYSTEM\CurrentControlSet\Services\Netlogon\Parameters` первоначально отсутствовал параметр `FullSecureChannelProtection`. Он создан как DWORD со значением 1; последующий вывод подтвердил записанное значение.

```
New-ItemProperty -Path 'HKLM:\SYSTEM\CurrentControlSet\Services\Netlogon\Parameters' `
  -Name FullSecureChannelProtection -PropertyType DWord -Value 1 -Force
```

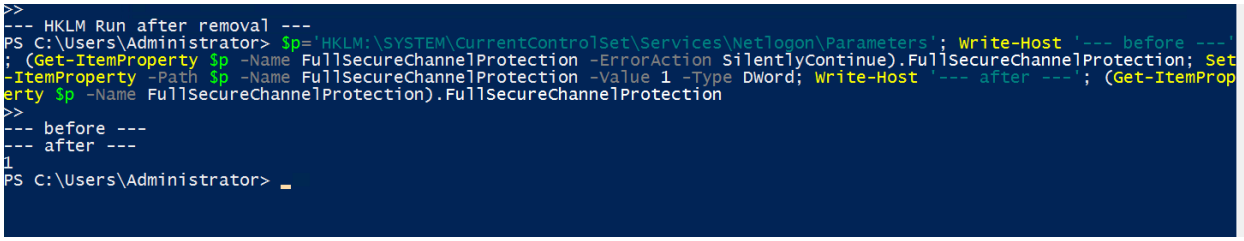


Рисунок 36 — Установка FullSecureChannelProtection в значение 1

Внесение параметра подтверждено, но перечень установленных обновлений Windows в материалах отсутствует. Поэтому полное устранение CVE-2020-1472 требует дополнительной

проверки исправлений и режима работы Netlogon. Повторная безопасная проверка должна подтвердить отклонение уязвимого варианта аутентификации без нарушения штатных доменных подключений.

6.4 Учётные записи и восстановление пароля

После Zerologon важна проверка машинного пароля контроллера. В ходе работы выполнен `netdom resetpwd` с указанием сервера AD и интерактивным вводом пароля доменного администратора. Команда завершилась ошибкой `The specified network name is no longer available`.

```
PS C:\Users\Administrator> netdom resetpwd /server:AD /userd:AMPIRE\administrator /passwordd:*
Type the password associated with the domain user:

The machine account password for the local machine could not be reset.

The specified network name is no longer available.

The command failed to complete successfully.

PS C:\Users\Administrator>
```

Рисунок 37 — Неуспешная попытка сброса машинного пароля через имя AD

Повторная попытка с полным именем `ad.ampire.corp` также завершилась ошибкой. Эти результаты означают, что запланированное восстановление пароля данной командой не подтверждено. Они не доказывают принципиальную невозможность изменения пароля контроллера домена.

```
PS C:\Users\Administrator> netdom resetpwd /server:ad.ampire.corp /userd:AMPIRE\administrator /passwordd:*
Type the password associated with the domain user:

The machine account password for the local machine could not be reset.

The specified network name is no longer available.

The command failed to complete successfully.

PS C:\Users\Administrator>
```

Рисунок 38 — Повторная ошибка netdom при использовании полного доменного имени

Дополнительно просмотрены 12 последних по времени создания учётных записей. В полученной выборке показаны даты 2019–2021 годов; новых записей от 28 октября не обнаружено. Это ограниченная проверка, которая не исключает изменения существующих пользователей, членства в группах или других объектов Active Directory.

```
PS C:\Users\Administrator> Get-ADUser -Filter * -Properties Created,LastLogonDate | Sort-Object Created -Descending | Se
lect-Object -First 12 Name,SamAccountName,Created,LastLogonDate | Format-Table -Auto

Name    SamAccountName Created              LastLogonDate
----    -------------- -------              -------------
it10    it10           11/17/2021 1:51:21 PM 10/25/2022 10:11:36 AM
it9     it9            11/17/2021 1:50:32 PM 10/28/2026 4:36:39 PM
it8     it8            11/17/2021 1:49:26 PM 10/25/2022 10:10:18 AM
it7     it7            11/17/2021 1:47:15 PM 10/24/2022 5:01:08 PM
it6     it6            11/17/2021 1:44:34 PM 10/24/2022 4:55:56 PM
VIP     vip            8/13/2020 3:20:25 PM  2/26/2021 9:51:19 AM
manager manager        8/13/2020 3:16:56 PM  9/20/2026 12:10:33 AM
it5     it5            2/25/2020 5:13:35 PM  10/28/2026 4:29:01 PM
it4     it4            9/7/2019 2:54:09 AM   10/24/2022 5:05:12 PM
it3     it3            9/7/2019 2:53:37 AM   11/11/2021 2:25:55 PM
it2     it2            9/7/2019 2:53:15 AM   10/24/2022 5:05:28 PM
it1     it1            9/7/2019 2:52:46 AM   10/24/2022 5:04:33 PM


PS C:\Users\Administrator>
```

Рисунок 39 — Проверка времени создания последних учётных записей AD

7 Расследование на сервере Exchange

7.1 Веб-шелл

В каталоге аутентификации OWA обнаружен `AM_Backdoor.aspx`. Полный путь каталога:

```
C:\Program Files\Microsoft\Exchange Server\V15\FrontEnd\HttpProxy\owa\auth
```

Размер файла — 109 байт, время изменения — 28 октября 16:13:44. Эта отметка находится вскоре после сетевых загрузок, зарегистрированных для MAIL.

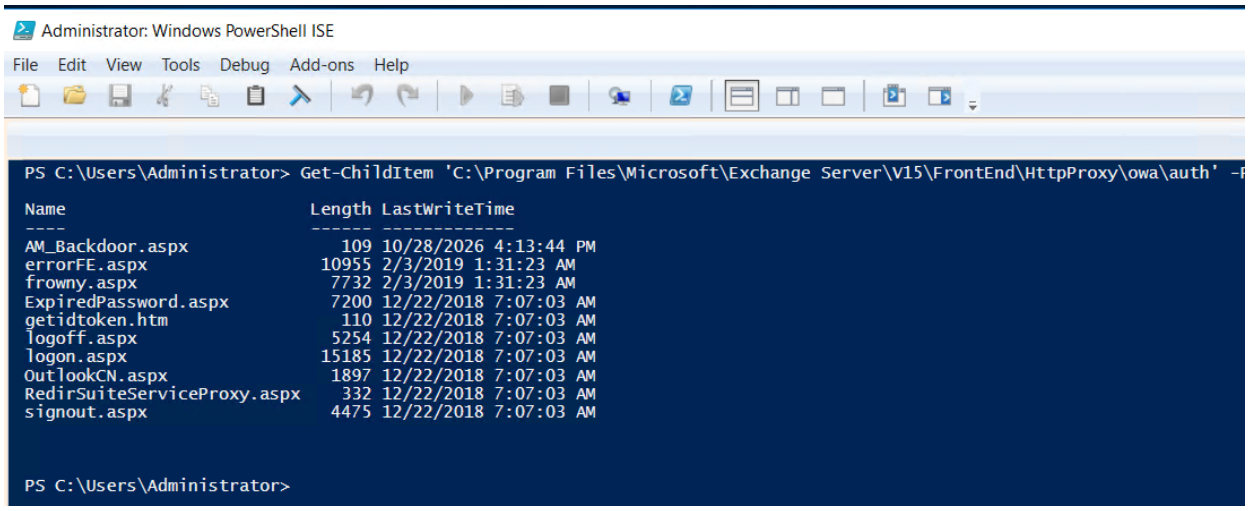


Рисунок 40 — Файл AM_Backdoor.aspx в каталоге OWA

Просмотр показал серверный JScript с обработчиком `Page_Load`, который передавал параметр HTTP-запроса `password` в `eval` с режимом `unsafe`. Такое содержимое позволяет выполнять переданный код и соответствует веб-шеллу типа China Chopper. Название параметра здесь является частью протокола обращения к бэкдору.

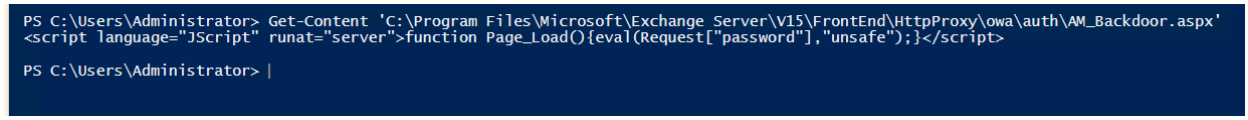


Рисунок 41 — Содержимое обнаруженного ASPX-веб-шелла

Файл удалён по точному пути; `Test-Path` вернул `False`. Зафиксировано удаление именно найденного `AM_Backdoor.aspx`.

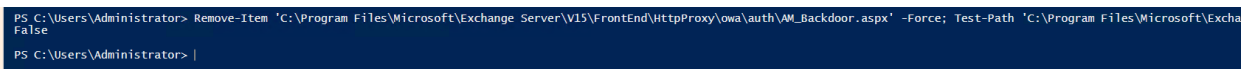


Рисунок 42 — Проверка отсутствия AM_Backdoor.aspx после удаления

Дополнительный просмотр каталогов ECP и OWA показал другие файлы с более ранними датами. Это помогло уточнить область поиска, но не заменило сверку всех файлов Exchange с эталоном и анализ журналов IIS.

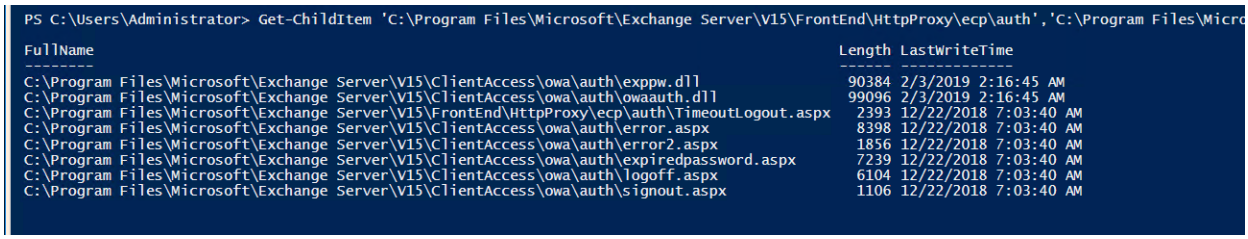


Рисунок 43 — Дополнительная проверка каталогов аутентификации Exchange

7.2 Учётные записи и службы

В локальном списке пользователей присутствовали Administrator, DefaultAccount, frunklin, Guest и John. Для John отдельно проверены параметры учётной записи: пароль установлен 19 октября 2021 года, последний вход не зарегистрирован, членство — Users. Имя пользователя само по себе не подтверждает создание учётной записи нарушителем, поэтому удаление по одному этому признаку не выполнялось.

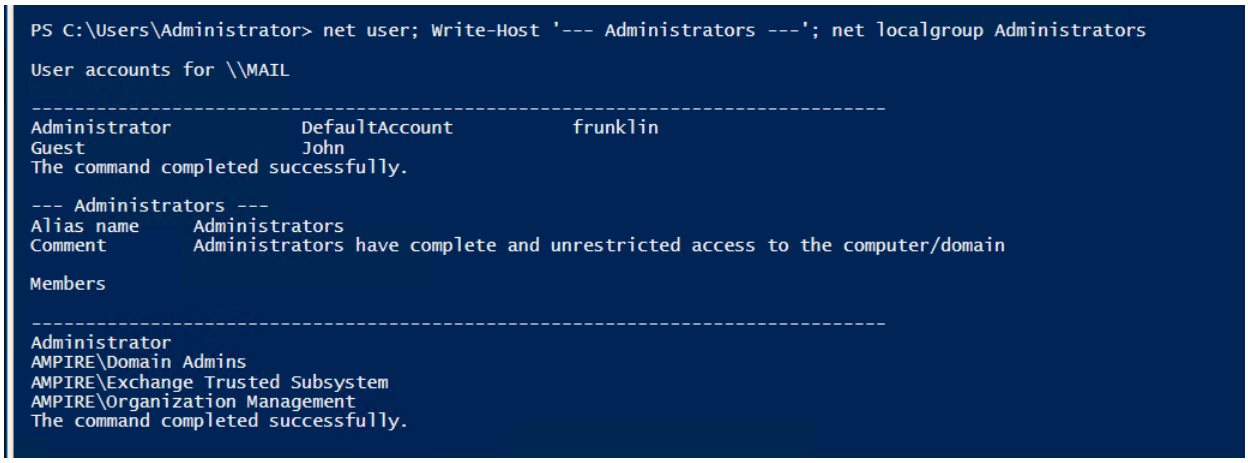


Рисунок 44 — Локальные учётные записи почтового сервера

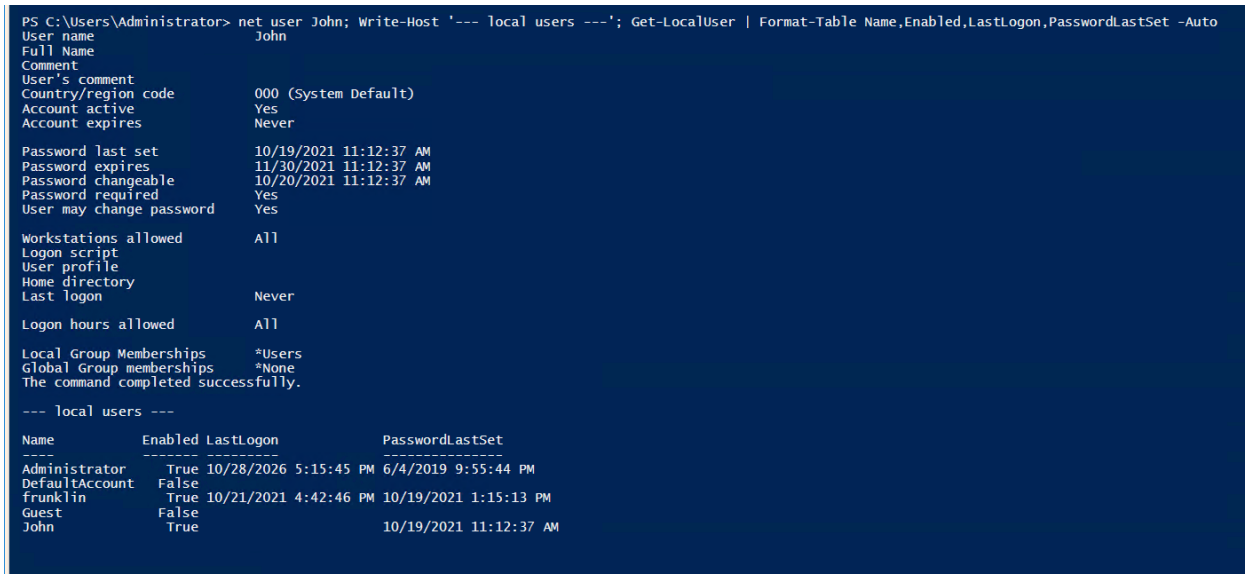


Рисунок 45 — Подробные сведения о локальном пользователе John

Exchange Management Shell не смогла установить рабочую сессию и сообщила `No Exchange servers are available in any Active Directory sites`. По одному сообщению нельзя установить причину: требовалась дополнительная диагностика конфигурации и служб управления.

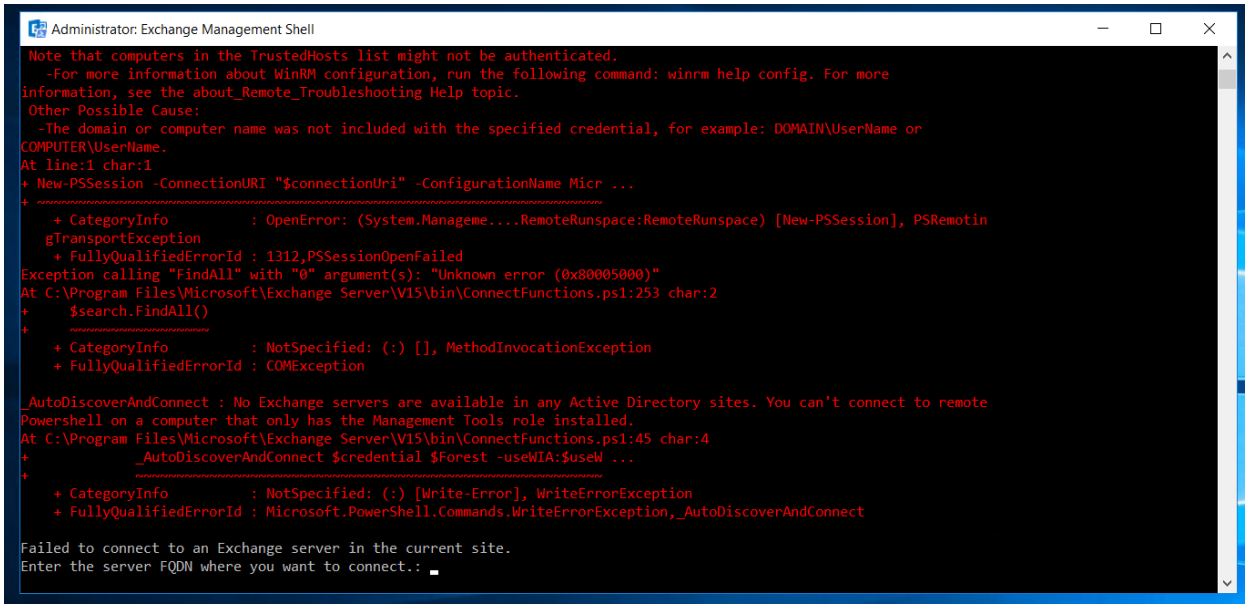


Рисунок 46 — Ошибка подключения Exchange Management Shell

Для проверки базовой доменной связи использованы `Test-ComputerSecureChannel` и `nltest /sc_verify:AMPIRE`. Получены `True` и `NERR_Success`. Эти результаты показывают успешную проверку защищённого канала MAIL с доменом в момент выполнения команды и не подтверждают предположение, что ошибка EMS вызвана нарушением именно этого канала.

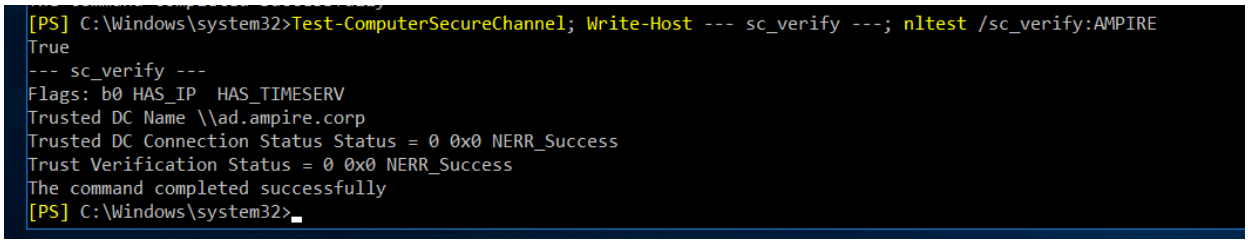


Рисунок 47 — Успешная проверка защищённого канала Exchange с доменом

Список служб Exchange содержал работающие и остановленные службы. Их состояние зафиксировано, однако отдельная проверка доставки почты и полного пользовательского сценария отсутствовала. Работоспособность всех почтовых функций только из этого списка не выводилась.

```
Machine:
[PS] C:\Windows\system32>Get-Service *Exchange* | Select-Object Status,Name,DisplayName | Format-Table -Auto

 Status Name                      DisplayName
 ------ ----                      -----------
Running MSExchangeADTopology      Microsoft Exchange Active Directory Topology
Running MSExchangeAntispamUpdate  Microsoft Exchange Anti-spam Update
Running MSExchangeCompliance      Microsoft Exchange Compliance Service
Running MSExchangeDagMgmt         Microsoft Exchange DAG Management
Running MSExchangeDelivery        Microsoft Exchange Mailbox Transport Delivery
Stopped MSExchangeDiagnostics     Microsoft Exchange Diagnostics
Running MSExchangeEdgeSync        Microsoft Exchange EdgeSync
Running MSExchangeFastSearch      Microsoft Exchange Search
Running MSExchangeFrontEndTransport Microsoft Exchange Frontend Transport
Running MSExchangeHM              Microsoft Exchange Health Manager
Running MSExchangeHMRecovery      Microsoft Exchange Health Manager Recovery
Running MSExchangeImap4           Microsoft Exchange IMAP4
Running MSExchangeIMAP4BE         Microsoft Exchange IMAP4 Backend
Running MSExchangeIS              Microsoft Exchange Information Store
Running MSExchangeMailboxAssistants Microsoft Exchange Mailbox Assistants
Running MSExchangeMailboxReplication Microsoft Exchange Mailbox Replication
Stopped MSExchangeNotificationsBroker Microsoft Exchange Notifications Broker
Stopped MSExchangePop3            Microsoft Exchange POP3
Stopped MSExchangePOP3BE          Microsoft Exchange POP3 Backend
Running MSExchangeRepl            Microsoft Exchange Replication
Running MSExchangeRPC             Microsoft Exchange RPC Client Access
Running MSExchangeServiceHost     Microsoft Exchange Service Host
Running MSExchangeSubmission      Microsoft Exchange Mailbox Transport Submission
Running MSExchangeThrottling      Microsoft Exchange Throttling
Running MSExchangeTransport       Microsoft Exchange Transport
Running MSExchangeTransportLogSearch Microsoft Exchange Transport Log Search
Running MSExchangeUM              Microsoft Exchange Unified Messaging
Running MSExchangeUMCR            Microsoft Exchange Unified Messaging Call Router
Running SearchExchangeTracing     Tracing Service for Search in Exchange
Stopped vmickvpexchange           Hyper-V Data Exchange Service
Stopped wsbexchange               Microsoft Exchange Server Extension for Windows Server Backup


[PS] C:\Windows\system32>
```

Рисунок 48 — Состояние служб Microsoft Exchange

7.3 Ограничение доступа к ECP

В IIS Manager выбрано приложение ecp сайта Default Web Site. Для него открыт раздел IP Address and Domain Restrictions. Изменение выполнялось на уровне приложения, чтобы ограничить поверхность административной панели.

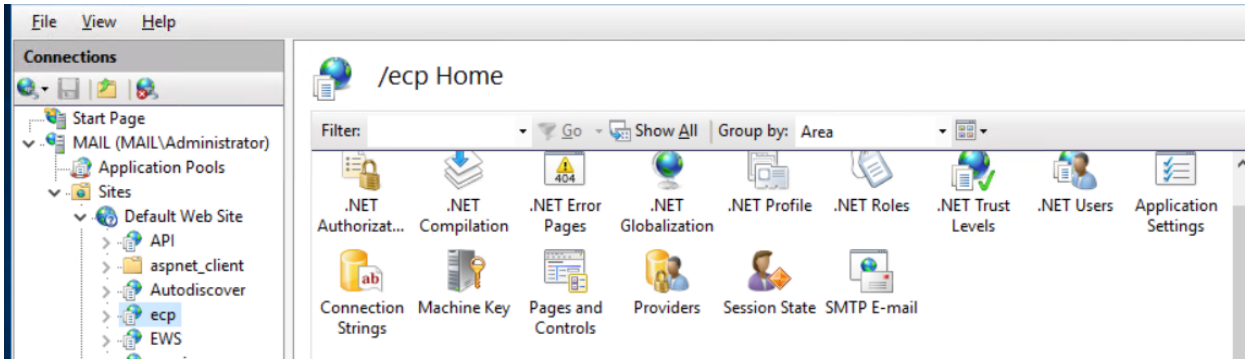


Рисунок 49 — Выбор приложения ecp в IIS Manager

В Edit Feature Settings для неуказанных клиентов установлен режим Deny и действие Not Found. Такая конфигурация запрещает доступ адресам, для которых нет разрешающего правила. Возможность последующего административного доступа необходимо учитывать при составлении списка разрешений.

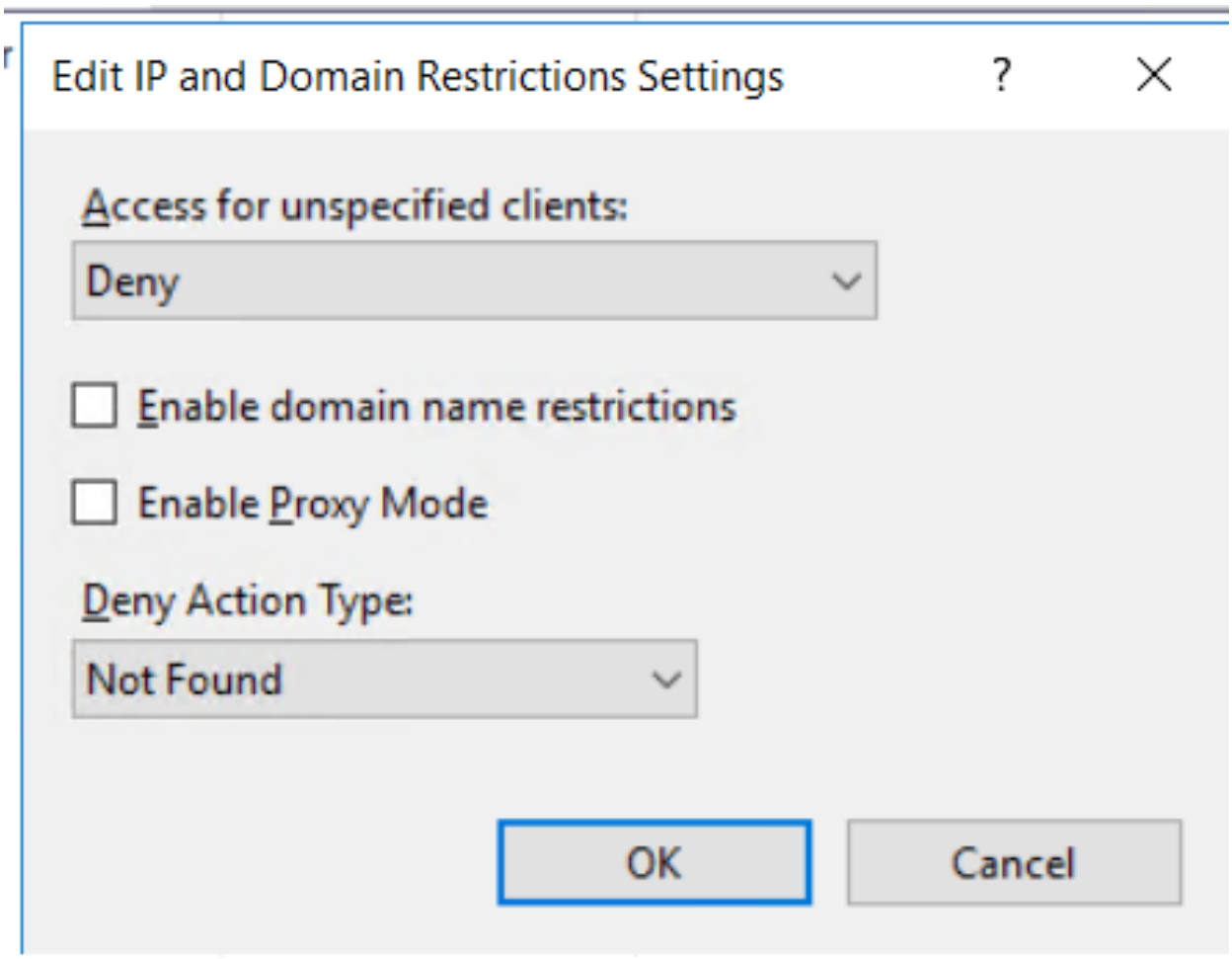


Рисунок 50 — Запрет доступа неуказанным клиентам и действие Not Found

Проверка эффективной конфигурации через `appcmd` показала `allowUnlisted="false"` и `denyAction="NotFound"`. Таким образом, сохранение ограничения подтверждено отдельно от интерфейса IIS.

```
[PS] C:\Windows\system32>& "$env:windir\system32\inetsrv\appcmd.exe" list config "Default Web Site/ecp" -section:system.webServer/security/ipSecur
ity
>>
<system.webServer>
  <security>
    <ipSecurity allowUnlisted="false" denyAction="NotFound">
    </ipSecurity>
  </security>
</system.webServer>
[PS] C:\Windows\system32>
```

Рисунок 51 — Проверка эффективного параметра ipSecurity для ECP

Достоверный ответ HTTP при обращении с запрещённого внешнего адреса в материалах не получен: часть команд отсутствовала либо не дала интерпретируемого результата. Поэтому подтверждена конфигурация ограничения, а не конкретный код отказа во внешней проверке. Установка обновления Exchange, устраняющего CVE-2020-0688, также не зафиксирована.

8 Инциденты и измерение результатов

8.1 Карточки инцидентов

В Ampire созданы карточки по трём затронутым системам. Для Exchange использовано название «Компрометация почтового сервера MS Exchange», время 16:13 и источник `195.239.174.11`. Для AD — «Компрометация контроллера домена (Zerologon)», время 16:12, источник `10.10.1.22`. Для WordPress — «Дефейс сайта и компрометация CMS WordPress», время 16:10, внешний источник `195.239.174.11`.

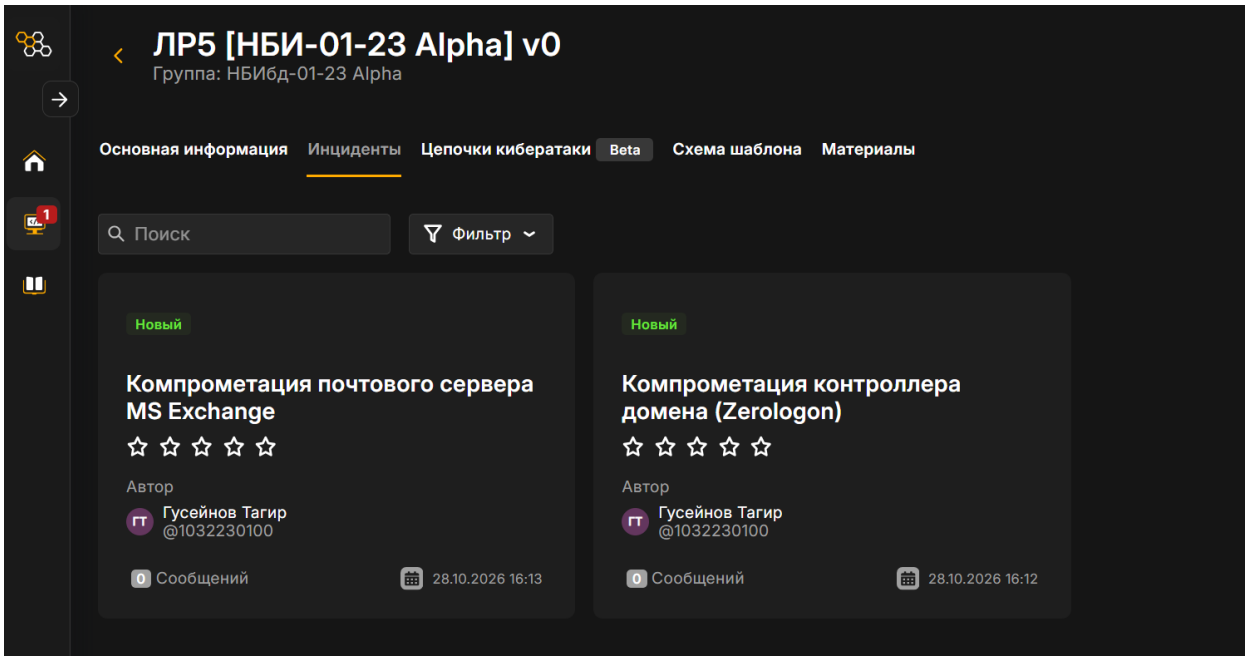


Рисунок 52 — Созданные карточки инцидентов Exchange и Active Directory

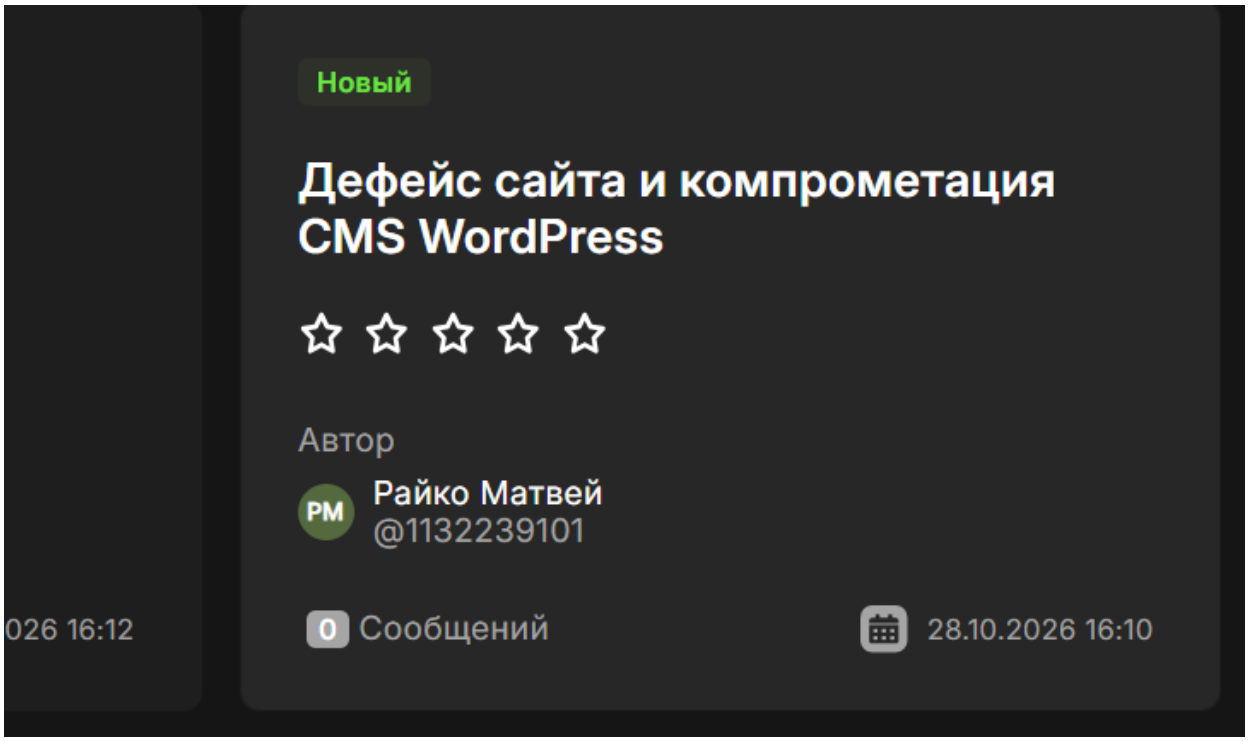


Рисунок 53 — Карточка инцидента по дефейсу и компрометации WordPress

Карточки фиксируют время, источник, затронутый актив и описание событий. Показанный статус «Новый» означает создание записи; он не равнозначен закрытию инцидента или успешной оценке лабораторной работы.

8.2 Результаты локальных проверок

В итоговом сопоставлении (таблица 3) приведены выполненные действия и практические границы их подтверждения. Такой способ подведения итогов позволяет отличить удалённый артефакт от полностью устранённой причины компрометации.

Таблица 3 — Подтверждённые результаты и оставшиеся проверки

Система	Подтверждённый результат	Что остаётся проверить
WordPress	Изображение восстановлено; два вредоносных плагина и 53 PHP-файла перемещены из веб-каталогов; Essential Addons отключён; сайт отображается	Целостность CMS и остальных плагинов, исправленная версия компонента, запрет PHP в uploads, смена скомпрометированных секретов
Active Directory	PID 3508 и python_backdoor.py удалены; запись hacker_backdoor отсутствует; FullSecureChannelProtection = 1	Наличие исправлений Windows, восстановление машинного пароля, другие точки закрепления, последствия доступа к домену
Exchange	AM_Backdoor.aspx удалён; ECP allowUnlisted = false; защищённый канал проверен успешно	Обновление Exchange, внешний тест ограничения ECP, журналы и целостность файлов, работа EMS и доставка почты

На доступном снимке общей страницы Ampire блоки уязвимостей и последствий сохраняли статус «Не устранено». Этот снимок не является итоговым доказательством после всех операций; последующее успешное принятие результатов автоматической проверкой также не зафиксировано.

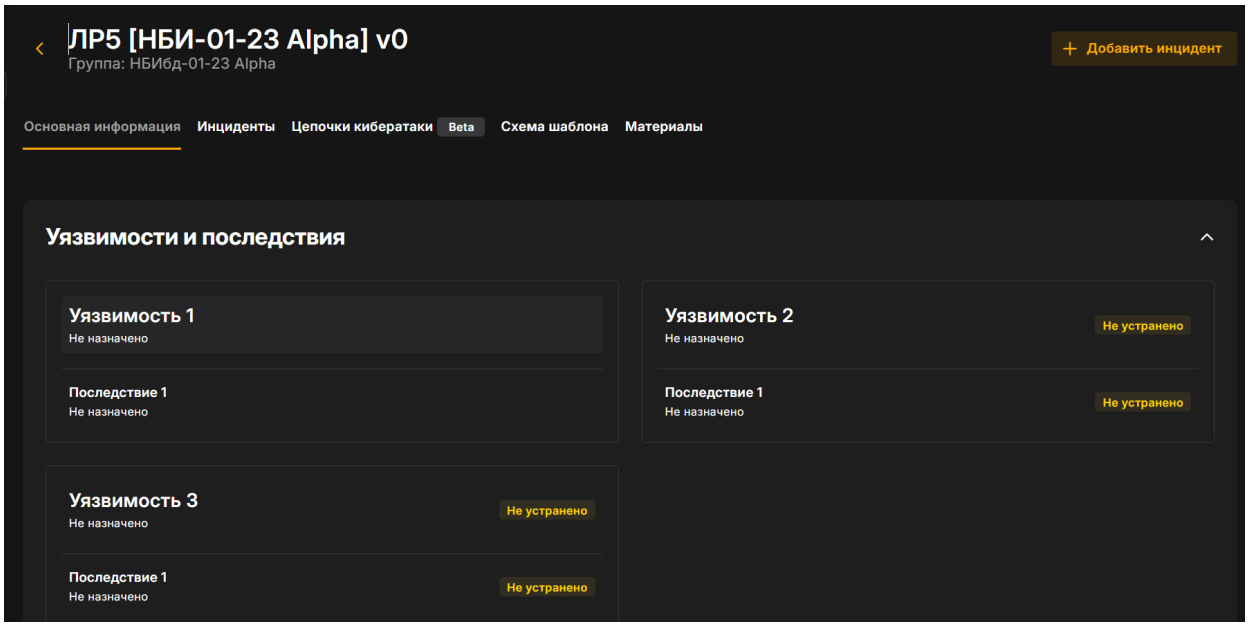


Рисунок 54 — Доступное состояние блоков уязвимостей и последствий Ampire

Следовательно, можно подтвердить выполненные локальные мероприятия, но нельзя заявить закрытие всех трёх уязвимостей и трёх последствий по счётчикам платформы. Причина расхождения с локальными результатами отдельно не установлена.

8.3 Оставшиеся меры

Для WordPress необходимы обновление CMS и доверенных расширений, установка исправленной версии Essential Addons либо отказ от компонента, сверка файлов с эталоном и запрет исполнения PHP в каталоге загрузок. Следует сменить учётные данные, которые могли стать доступны нарушителю, проверить административные сессии и назначенные задания. Перемещённые образцы необходимо сохранить для анализа и исключить их возврат в рабочий веб-каталог.

Для Active Directory требуется подтвердить установку обновлений против Zerologon, исследовать причину ошибок `netdom resetpwd` и завершить восстановление машинного пароля по процедуре Microsoft. С учётом доступа к контроллеру следует расширить анализ на изменения групп, привилегированных пользователей, служб и задач. Удаление одного Python-бэкдора не доказывает восстановление доверия ко всему домену.

Для Exchange требуется установить соответствующие обновления, проверить журналы IIS и события запуска процессов за период атаки, выполнить внешнюю проверку ECP и восстановить работу EMS. Проверку доставки почты следует провести отдельным пользовательским тестом. После технических проверок необходимо повторно проверить состояния Ampire и завершить карточки инцидентов с результатами и подтверждениями.

9 Заключение

В ходе лабораторной работы восстановлена наблюдаемая последовательность атаки на инфраструктуру ЦОД: активность против WordPress, запросы Zerologon от веб-сервера к контроллеру домена и последующие сетевые загрузки на Exchange. Сопоставление событий IDS с временными метками файлов и процессов позволило определить конкретные объекты для реагирования.

На WordPress восстановлено изображение сайта, удалены из веб-каталогов два вредоносных плагина и 53 PHP-файла, отключён Essential Addons версии 5.7.1. На контроллере домена остановлен Python-бэкдор, удалены его файл и запись автозапуска, установлен защитный параметр Netlogon. На Exchange удалён ASPX-веб-шелл и сохранено ограничение доступа к ECP. По трём эпизодам созданы карточки инцидентов.

Работа также выявила незавершённые мероприятия: обе попытки сброса машинного пароля контроллера завершились ошибкой, установка необходимых обновлений не подтверждена, внешний HTTP-тест ограничения ECP и автоматическое принятие всех результатов Ampire не зафиксированы. Практический итог — выполненная очистка обнаруженных артефактов и частичное восстановление систем с определённым перечнем последующих проверок.